

NIST SP 800-53 Rev 5 control SI-22 (Information Diversity) summarizes the requirements for this control: SI-22 · Information Diversity Control Statement: a. Identify the following alternative sources of information for [organization-defined parameter]: [organization-defined parameter] ; and b. Use an alternative information source for the execution of essential functions or services on [organization-defined parameter] when the primary source of information is corrupted or unavailable. Supplemental Guidance: a. Identify the following alternative sources of information for [organization-defined par

SI-4.13 · Analyze Traffic and Event Patterns Control Statement: (a) Analyze communications traffic and event patterns for the system; (b) Develop profiles representing common traffic and event patterns; and (c) Use the traffic and event profiles in tuning system-monitoring devices. Supplemental Guidance: (a) Analyze communications traffic and event patterns for the system; (b) Develop profiles representing common traffic and event patterns; and (c) Use the traffic and event profiles in tuning system-monitoring devices. Identifying and understanding common communications traffic and event patterns help organizations provide useful information to system monitoring devices to more effectively identify suspicious or anomalous traffic and events when they occur. Such information can help reduce the number of false positives and false negatives during system monitoring.

Control SI-12(3): Nation. Security and privacy risks arise from the planning and execution of organizational mission and business functions, placing information systems into operation, or continuing system operations. Realistic assessments of risk require a thorough understanding of the susceptibility to threats based on the specific vulnerabilities in information systems and organizations and the likelihood and potential adverse impacts of successful exploitations of such vulnerabilities by those threats.¹⁵ Risk assessments also require an understanding of privacy risks.¹⁶ To address the organization-s concerns about assessment and determination of risk, security and privacy requirements are satisfied with the knowledge and understanding of the organizational risk management strategy.¹⁷ The risk management strategy considers the cost, schedule, performance, and supply chain issues associated with the design, development, acquisition, deployment, operation, sustainment, and disposal of organizational systems. A risk management process is then applied to manage risk on an ongoing basis.¹⁸ The catalog of security and privacy controls can be effectively used to protect organizations, individuals, and information systems from traditional and advanced persistent threats and privacy risks arising from the processing of personally identifiable information (PII) in varied operational, environmental, and technical scenarios. The controls can be used to demonstrate compliance with a variety of governmental, organizational, or institutional security and privacy requirements.

NIST SP 800-171 Rev 3 control 03.14.01 (03.14.01 Flaw Remediation) is assessed by examining the following: Assessment Objectives: - system flaws are identified. - system flaws are reported. - system flaws are corrected. - security-relevant software updates are installed within [organization-defined parameter] of the release of the updates. - security-relevant firmware updates are installed within [organization-defined parameter] of the release of the updates.

NIST SP 800-53 Rev 5 control SI-10 (Information Input Validation) is defined as follows: SI-10 · Information Input Validation Control Statement: Check the validity of the following information inputs: [organization-defined parameter]. Supplemental Guidance: Check the validity of the following information inputs: [organization-defined parameter]. Checking the valid syntax and semantics of system inputs-including character set, length, numerical range, and acceptable values-verifies that inputs match specified definitions for format and content. For example, if the organization specifies that numerical values between 1-100 are the only acceptable inputs for a field in a given appl

NIST SP 800-53 Rev 5 control SI-12.3 (Information Disposal) summarizes the requirements for this control: SI-12.3 · Information Disposal Control Statement: Use the following techniques to dispose of, destroy, or erase information following the retention period: [organization-defined parameter]. Supplemental Guidance: Use the following techniques to dispose of, destroy, or erase information following the retention period: [organization-defined parameter]. Organizations can minimize both security and privacy risks by disposing of information when it is no longer needed. The disposal or destruction o

NIST SP 800-171 Rev 3 control 03.14.08 (03.14.08 Information Management and Retention) is assessed by examining the following: Assessment Objectives: - CUI within the system is managed in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements. - CUI within the system is retained in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements. - CUI output from the system is managed in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements. - CUI output from the system is retained

NIST SP 800-53 Rev 5 control SI-7.2 (Automated Notifications of Integrity Violations) is assessed by examining, interviewing, and testing: SI-7.2 · Automated Notifications of Integrity Violations Control Statement: Employ automated tools that provide notification to [organization-defined parameter] upon discovering discrepancies during integrity verification. Supplemental Guidance: Employ automated tools that provide notification to [organization-defined parameter] upon discovering discrepancies during integrity verification. The employment of automated tools to report system and information integrity violations and to notify org

NIST SP 800-171 Rev 3 control 03.14.06 (03.14.06 System Monitoring) is assessed by examining the following: Assessment Objectives: - the system is monitored to detect attacks. - the system is monitored to detect indicators of potential attacks. - the system is monitored to detect unauthorized connections. - unauthorized use of the system is identified. - inbound communications traffic is monitored to detect unusual or unauthorized activities or conditions. - outbound communications traffic is monitored to detect unusual or unauthorized activities or conditions.

NIST SP 800-53 Rev 5 control SI-10.5 (Restrict Inputs to Trusted Sources and Approved Formats) is assessed by examining, interviewing, and testing: SI-10.5 · Restrict Inputs to Trusted Sources and Approved Formats Control Statement: Restrict the use of information inputs to [organization-defined parameter] and/or [organization-defined parameter]. Supplemental Guidance: Restrict the use of information inputs to [organization-defined parameter] and/or [organization-defined parameter]. Restricting the use of inputs to trusted sources and in trusted formats applies the concept of authorized or permitted software to information inputs. Specify

NIST SP 800-53 Rev 5 control SI-21 (Information Refresh) summarizes the requirements for this control: SI-21 · Information Refresh Control Statement: Refresh [organization-defined parameter] at [organization-defined parameter] or generate the information on demand and delete the information when no longer needed. Supplemental Guidance: Refresh [organization-defined parameter] at [organization-defined parameter] or generate the information on demand and delete the information when no longer needed. Retaining information for longer than it is needed makes it an increasingly valuable and enticing

Under the FedRAMP High baseline, SI-5 (SI-5 Security Alerts, Advisories, and Directives): FedRAMP High Baseline · SI-5 · Security Alerts, Advisories, and Directives Control Statement: a. Receive system security alerts, advisories, and directives from [organization-defined parameter] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [organization-defined parameter] ; and d. Implement security directives in accordance with established time frames, or notify the issui

NIST SP 800-53 Rev 5 control SI-2.2 (Automated Flaw Remediation Status) is defined as follows: SI-2.2 · Automated Flaw Remediation Status Control Statement: Determine if system components have applicable security-relevant software and firmware updates installed using [organization-defined parameter] [organization-defined parameter]. Supplemental Guidance: Determine if system components have applicable security-relevant software and firmware updates installed using [organization-defined parameter] [organization-defined parameter]. Automated mechanisms can track and determine the status of known flaws for system components.

NIST SP 800-53 Rev 5 control SI-10.3 (Predictable Behavior): SI-10.3 · Predictable Behavior Control Statement: Verify that the system behaves in a predictable and documented manner when invalid inputs are received. Supplemental Guidance: Verify that the system behaves in a predictable and documented manner when invalid inputs are received. A common vulnerability in organizational systems is unpredictable behavior when invalid inputs are received. Verifica

NIST SP 800-53 Rev 5 control SI-14.1 (Refresh from Trusted Sources) summarizes the requirements for this control: SI-14.1 · Refresh from Trusted Sources Control Statement: Obtain software and data employed during system component and service refreshes from the following trusted sources: [organization-defined parameter]. Supplemental Guidance: Obtain software and data employed during system component and service refreshes from the following trusted sources: [organization-defined parameter]. Trusted sources include software and data from write-once, read-only media or from selected offline secure storage fa

NIST SP 800-53 Rev 5 control SI-7.7 (Integration of Detection and Response) is assessed by examining, interviewing, and testing: SI-7.7 · Integration of Detection and Response Control Statement: Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [organization-defined parameter]. Supplemental Guidance: Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [organization-defined parameter]. Integrating detection and response helps to ensure that detected events are tracked, monitored, corrected

SI-14.1 · Refresh from Trusted Sources Control Statement: Obtain software and data employed during system component and service refreshes from the following trusted sources: [organization-defined parameter]. Supplemental Guidance: Obtain software and data employed during system component and service refreshes from the following trusted sources: [organization-defined parameter]. Trusted sources include software and data from write-once, read-only media or from selected offline secure storage facilities.

NIST SP 800-53 Rev 5 control SI-4.13 (Analyze Traffic and Event Patterns) summarizes the requirements for this control: SI-4.13 · Analyze Traffic and Event Patterns Control Statement: (a) Analyze communications traffic and event patterns for the system; (b) Develop profiles representing common traffic and event patterns; and (c) Use the traffic and event profiles in tuning system-monitoring devices. Supplemental Guidance: (a) Analyze communications traffic and event patterns for the system; (b) Develop profiles representing common traffic and event patterns; and (c) Use the traffic and event profiles in tuning

Under the FedRAMP High baseline, SI-7.5 (SI-7.5 Automated Response to Integrity Violations): FedRAMP High Baseline · SI-7.5 · Automated Response to Integrity Violations Control Statement: Automatically [organization-defined parameter] when integrity violations are discovered. Supplemental Guidance: Automatically [organization-defined parameter] when integrity violations are discovered. Organizations may define different integrity-checking responses by type of information, specific information, or a combination of both. Types of information include firmware, software, and user data. Sp

NIST SP 800-53 Rev 5 control SI-8 (Spam Protection) is assessed by examining, interviewing, and testing: SI-8 · Spam Protection Control Statement: a. Employ spam protection mechanisms at system entry and exit points to detect and act on unsolicited messages; and b. Update spam protection mechanisms when new releases are available in accordance with organizational configuration management policy and procedures. Supplemental Guidance: a. Employ spam protection mechanisms at system entry and exit points to detect and act on unsolicited messages; and b. Update spam protection mechanisms when new rele

NIST asks the commercial satellite operations community to use this document as an informative reference to assist in managing cybersecurity risks and to consider how cybersecurity requirements might coexist within space vehicle system requirements. The example requirements listed in this document could be used to create an initial baseline. However, NIST recommends that organizations use this document in coordination with NIST references and applicable SSO materials to create customized cybersecurity outcomes, requirements, and controls to support an organization's particular business needs and address its individual threat models. | Functions | Subcategories | Informative | Reference | |-----|-----|

-----|-----|-----|
-----| | | SP 800-53, Rev. 4 | SP 800-53, Rev. 5 | | PR.DS-6:
Integrity-checking mechanisms are used to verify software, firmware, and information integrity. |

SI-7 | SI-7, SI-10 || PR.DS-8: Integrity-checking mechanisms are used to verify hardware integrity.

NIST SP 800-53 Rev 5 control SI-19.2 (Archiving) summarizes the requirements for this control: SI-19.2 · Archiving Control Statement: Prohibit archiving of personally identifiable information elements if those elements in a dataset will not be needed after the dataset is archived. Supplemental Guidance: Prohibit archiving of personally identifiable information elements if those elements in a dataset will not be needed after the dataset is archived. Datasets can be archived for many reasons. The envisioned purposes for the archived dataset are specified, and if personally identifiable in

NIST SP 800-171 Rev 3 control 03.14.06 (03.14.06 System Monitoring) is assessed by examining the following: Assessment Objectives: - the system is monitored to detect attacks. - the system is monitored to detect indicators of potential attacks. - the system is monitored to detect unauthorized connections. - unauthorized use of the system is identified. - inbound communications traffic is monitored to detect unusual or unauthorized activities or conditions. - outbound communications traffic is monitored to detect unusual or unauthorized activities or conditions.

NIST SP 800-53 Rev 5 control SI-2.7 (Root Cause Analysis) summarizes the requirements for this control: SI-2.7 · Root Cause Analysis Control Statement: a. Conduct root cause analysis to identify underlying causes of issues or failures. b. Develop actions to address the root cause of the issue or failure. c. Implement the actions and monitor the implementation for effectiveness. Supplemental Guidance: a. Conduct root cause analysis to identify underlying causes of issues or failures. b. Develop actions to address the root cause of the issue or failure. c. Implement the actions and monitor the imp

NIST SP 800-53 Rev 5 control SI-17 (Fail-safe Procedures): SI-17 · Fail-safe Procedures Control Statement: Implement the indicated fail-safe procedures when the indicated failures occur: [organization-defined parameter]. Supplemental Guidance: Implement the indicated fail-safe procedures when the indicated failures occur: [organization-defined parameter]. Failure conditions include the loss of communications among critical system components or between s

NIST SP 800-53 Rev 5 control SI-19.4 (Removal, Masking, Encryption, Hashing, or Replacement of Direct Identifiers) summarizes the requirements for this control: SI-19.4 · Removal, Masking, Encryption, Hashing, or Replacement of Direct Identifiers Control Statement: Remove, mask, encrypt, hash, or replace direct identifiers in a dataset. Supplemental Guidance: Remove, mask, encrypt, hash, or replace direct identifiers in a dataset. There are many possible processes for removing direct identifiers from a dataset. Columns in a dataset that contain a direct identifier can be removed. In masking, the direct identifier is transformed into a repeating charac

This requirement is sourced to a control tailored out of the SP 800-53B 2288 [13] moderate baseline in SP 800-1 71. PR OTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: SI-16 03.14.15E Non-P ersistent System Components and Services a. Implement non-persistent [Assignment: organization-defined system components and services] . b. Initiate non-persistent system components and services from a known state. c. Terminate non-persistent system components and services [Selection (one or more): upon end of session of use; [Assignment: organization-defined frequency]]. DISCUSSION Implementation of non-persistent components and services mitigates risk from advanced persistent threats (APTs) by reducing the targeting capability of adversaries (i.e., window of opportunity and available attack surface) to initiate and complete attacks. By implementing the concept of non-persistence for selected system components and services, organizations can provide a trusted computing resource for a specific time period that does not give adversaries sufficient time to exploit vulnerabilities in their systems and operating environments. The use of non- persistent components and services mitigates risk by limiting the targeting capability of adversaries (i.e., reducing the window of opportunity and available attack surface) to initiate and complete attacks. Non-persistent system components and services are activated as required from a known (trusted) state and terminated periodically or at the end of sessions. The use of non-persistent system components and services also increases the work factor of adversaries. Non-persistence can be achieved by refreshing system components, periodically reimaging components, or using a variety of common virtualization techniques. Non-persistent services can be implemented by using virtual machines or as new instances of processes

on physical machines (persistent or non-persistent). The benefit of periodic refreshes of system components and services is that it does not require organizations to determine in advance whether compromises have occurred,

NIST SP 800-171 Rev 3 control 03.14.08 (03.14.08 Information Management and Retention) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Information Integrity (SI) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SI-6.2 (Automation Support for Distributed Testing) is assessed by examining, interviewing, and testing: SI-6.2 · Automation Support for Distributed Testing Control Statement: Implement automated mechanisms to support the management of distributed security and privacy function testing. Supplemental Guidance: Implement automated mechanisms to support the management of distributed security and privacy function testing. The use of automated mechanisms to support the management of distributed function testing helps to ensure the integrity, timeliness, completeness, and efficacy of such testing.

NIST SP 800-53 Rev 5 control SI-4.3 (Automated Tool and Mechanism Integration) is assessed by examining, interviewing, and testing: SI-4.3 · Automated Tool and Mechanism Integration Control Statement: Employ automated tools and mechanisms to integrate intrusion detection tools and mechanisms into access control and flow control mechanisms. Supplemental Guidance: Employ automated tools and mechanisms to integrate intrusion detection tools and mechanisms into access control and flow control mechanisms. Using automated tools and mechanisms to integrate intrusion detection tools and mechanisms into access and flow control mech

NIST SP 800-53 Rev 5 control SI-3.8 (Detect Unauthorized Commands) is assessed by examining, interviewing, and testing: SI-3.8 · Detect Unauthorized Commands Control Statement: (a) Detect the following unauthorized operating system commands through the kernel application programming interface on [organization-defined parameter]: [organization-defined parameter] ; and (b) [organization-defined parameter]. Supplemental Guidance: (a) Detect the following unauthorized operating system commands through the kernel application programming interface on [organization-defined parameter]: [organization-defined parameter]

NIST SP 800-53 Rev 5 control SI-12.3 (Information Disposal) is assessed by examining, interviewing, and testing: SI-12.3 · Information Disposal Control Statement: Use the following techniques to dispose of, destroy, or erase information following the retention period: [organization-defined parameter]. Supplemental Guidance: Use the following techniques to dispose of, destroy, or erase information following the retention period: [organization-defined parameter]. Organizations can minimize both security and privacy risks by disposing of information when it is no longer needed. The disposal or destruction o

Under the FedRAMP High baseline, SI-7.7 (SI-7.7 Integration of Detection and Response): FedRAMP High Baseline · SI-7.7 · Integration of Detection and Response Control Statement: Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [organization-defined parameter]. Supplemental Guidance: Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [organization-defined parameter]. Integrating detection and response helps to ensure that detected events are track

NIST SP 800-171 Rev 3 control 03.14.03 (03.14.03 Security Alerts, Advisories, and Directives) requires organizations to implement the following: Control Statement: SR-03.14.03.a Receive system security alerts, advisories, and directives from external organizations on an ongoing basis. SR-03.14.03.b Generate and disseminate internal system security alerts, advisories, and directives, as necessary. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.14.03.

NIST SP 800-53 Rev 5 control SI-19 (De-identification) is assessed by examining, interviewing, and testing: SI-19 · De-identification Control Statement: a. Remove the following elements of

personally identifiable information from datasets: [organization-defined parameter] ; and b. Evaluate [organization-defined parameter] for effectiveness of de-identification. Supplemental Guidance: a. Remove the following elements of personally identifiable information from datasets: [organization-defined parameter] ; and b. Evaluate [organization-defined parameter] for effectiveness of de-identification. De-ident

NIST SP 800-171 Rev 3 control 03.14.03 (03.14.03 Security Alerts, Advisories, and Directives) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Information Integrity (SI) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SI-19.7 (Validated Algorithms and Software) summarizes the requirements for this control: SI-19.7 · Validated Algorithms and Software Control Statement: Perform de-identification using validated algorithms and software that is validated to implement the algorithms. Supplemental Guidance: Perform de-identification using validated algorithms and software that is validated to implement the algorithms. Algorithms that appear to remove personally identifiable information from a dataset may in fact leave information that is personally identifiable or data that is re-identifiable. Softwar

SI-7.9 · Verify Boot Process Control Statement: Verify the integrity of the boot process of the following system components: [organization-defined parameter]. Supplemental Guidance: Verify the integrity of the boot process of the following system components: [organization-defined parameter]. Ensuring the integrity of boot processes is critical to starting system components in known, trustworthy states. Integrity verification mechanisms provide a level of assurance that only trusted code is executed during boot processes.

Implementing 03.14.01 (03.14.01 Flaw Remediation) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.14.01 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.14.01 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control SI-3.4 (Updates Only by Privileged Users) summarizes the requirements for this control: SI-3.4 · Updates Only by Privileged Users Control Statement: Update malicious code protection mechanisms only when directed by a privileged user. Supplemental Guidance: Update malicious code protection mechanisms only when directed by a privileged user. Protection mechanisms for malicious code are typically categorized as security-related software and, as such, are only updated by organizational personnel with appropriate access privileges.

NIST SP 800-53 Rev 5 control SI-7.8 (Auditing Capability for Significant Events) is assessed by examining, interviewing, and testing: SI-7.8 · Auditing Capability for Significant Events Control Statement: Upon detection of a potential integrity violation, provide the capability to audit the event and initiate the following actions: [organization-defined parameter]. Supplemental Guidance: Upon detection of a potential integrity violation, provide the capability to audit the event and initiate the following actions: [organization-defined parameter]. Organizations select response actions based on types of software, specific sof

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: SI-03 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.14.02.c.01 [Assignment: organization-defined frequency] at least weekly Planning 3.15.1 Policy and Procedure Development a. Develop, document, and disseminate to organizational personnel or roles the policies and procedures needed to satisfy the security requirements for the protection of CUI. b. Review and update policies and procedures

[Assignment: organization-defined frequency] (03.15.01.b). Related Controls: AC-01, AT-01, AU-01, CA-01, CM-01, IA-01, IR-01, MA-01, MP-01, PE-01, PL-01, PS-01, RA-01, SA-01, SC-01, SI-01, SR-01
ODP Values ODP Identifier ODP Assignment Text ODP Value 03.15.01.b [Assignment: organization-defined frequency] at least every 12 months, or when there are significant

NIST SP 800-53 Rev 5 control SI-3.10 (Malicious Code Analysis) is assessed by examining, interviewing, and testing: SI-3.10 · Malicious Code Analysis Control Statement: (a) Employ the following tools and techniques to analyze the characteristics and behavior of malicious code: [organization-defined parameter] ; and (b) Incorporate the results from malicious code analysis into organizational incident response and flaw remediation processes. Supplemental Guidance: (a) Employ the following tools and techniques to analyze the characteristics and behavior of malicious code: [organization-defined parameter] ; and

Control SI-8: d Controls: None. (3) SPAM PROTECTION |CONTINUOUS LEARNING CAPABILITY Implement spam protection mechanisms with a learning capability to more effectively identify legitimate communications traffic. Discussion: Learning mechanisms include Bayesian filters that respond to user inputs that identify specific traffic as spam or legitimate by updating algorithm parameters and thereby more accurately separating types of traffic. Related Controls: None. References: [SP 800-45], [SP 800-177].

NIST SP 800-53 Rev 5 control SI-7.1 (Integrity Checks) is assessed by examining, interviewing, and testing: SI-7.1 · Integrity Checks Control Statement: Perform an integrity check of [organization-defined parameter] [organization-defined parameter]. Supplemental Guidance: Perform an integrity check of [organization-defined parameter] [organization-defined parameter]. Security-relevant events include the identification of new threats to which organizational systems are susceptible and the installation of new hardware, software, or firmware. Transitional states include system startup, restart, shutdown

NIST SP 800-171 Rev 3 control 03.14.02 (03.14.02 Malicious Code Protection) is assessed by examining the following: Assessment Objectives: - malicious code protection mechanisms are implemented at system entry and exit points to detect malicious code. - malicious code protection mechanisms are implemented at system entry and exit points to eradicate malicious code. - malicious code protection mechanisms are updated as new releases are available in accordance with configuration management policy and procedures. - malicious code protection mechanisms are configured to perform scans of the system [organization-defined parameter]. - malicious code protection mechanisms are configured to block malicious code, qu

Under the FedRAMP High baseline, SI-10 (SI-10 Information Input Validation): FedRAMP High Baseline · SI-10 · Information Input Validation Control Statement: Check the validity of the following information inputs: [organization-defined parameter]. Supplemental Guidance: Check the validity of the following information inputs: [organization-defined parameter]. Checking the valid syntax and semantics of system inputs-including character set, length, numerical range, and acceptable values-verifies that inputs match specified definitions for format and content. For example,

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement is sourced to a control tailored out of the SP 2222 800-53B [13] moderate baseline in SP 800- 171. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Expose (Detect) REFERENCES Source Control: SI-07(07) 03.14.12E Information Input Validation Check the validity of the following information inputs: [Assignment: organization-defined information inputs to the system]. DISCUSSION Checking the valid syntax and semantics of system inputs-including character set, length, numerical range, and acceptable values-verifies that inputs match specified definitions for format and content. Valid inputs are likely to vary from field to field within a software application. Applications typically follow well-defined protocols that use structured messages (i.e., commands or queries)

NIST SP 800-53 Rev 5 control SI-10.6 (Injection Prevention) is assessed by examining, interviewing, and testing: SI-10.6 · Injection Prevention Control Statement: Prevent untrusted data injections. Supplemental Guidance: Prevent untrusted data injections. Untrusted data injections may be prevented using a parameterized interface or output escaping (output encoding). Parameterized interfaces separate data from code so that injections of malicious or unintended data cannot change the semantics of commands being sent. Output escaping uses specified characters to inform the

interpreter's parser whether data

From the NIST SP 800-172 Rev 3 Final Public Draft: Source Control: SI-07(06) 03.14.10 E Protection of Boot Firmware Implement the following mechanisms to protect the integrity of boot firmware in [Assignment: organization-defined system components]: [Assignment: organization-defined mechanisms]. DISCUSSION Unauthorized modifications to boot firmware may indicate a sophisticated, targeted attack. These types of targeted attacks can result in a permanent denial of service or a persistent malicious code presence. These situations can occur if the firmware is corrupted or malicious code is embedded in the firmware. System components can protect the integrity of boot firmware in organizational systems by verifying the integrity and authenticity of updates to the firmware prior to applying changes to the system component and preven

NIST SP 800-53 Rev 5 control SI-4.9 (Testing of Monitoring Tools and Mechanisms) is assessed by examining, interviewing, and testing: SI-4.9 · Testing of Monitoring Tools and Mechanisms Control Statement: Test intrusion-monitoring tools and mechanisms [organization-defined parameter]. Supplemental Guidance: Test intrusion-monitoring tools and mechanisms [organization-defined parameter]. Testing intrusion-monitoring tools and mechanisms is necessary to ensure that the tools and mechanisms are operating correctly and continue to satisfy the monitoring objectives of organizations. The frequency and depth of testing depends on t

NIST SP 800-53 Rev 5 control SI-5 (Security Alerts, Advisories, and Directives) summarizes the requirements for this control: SI-5 · Security Alerts, Advisories, and Directives Control Statement: a. Receive system security alerts, advisories, and directives from [organization-defined parameter] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [organization-defined parameter] ; and d. Implement security directives in accordance with established time frames, or notify the issuing organization of the d

Under the FedRAMP High baseline, SI-3 (SI-3 Malicious Code Protection): FedRAMP High Baseline · SI-3 · Malicious Code Protection Control Statement: a. Implement [organization-defined parameter] malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code; b. Automatically update malicious code protection mechanisms as new releases are available in accordance with organizational configuration management policy and procedures; c. Configure malicious code protection mechanisms to: 1. Perform periodic scans of the system

NIST SP 800-171 Rev 3 control 03.14.08 (03.14.08 Information Management and Retention) is assessed by examining the following: Assessment Objectives: - CUI within the system is managed in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements. - CUI within the system is retained in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements. - CUI output from the system is managed in accordance with applicable laws, Executive Orders, directives, regulations, policies, standards, guidelines, and operational requirements. - CUI output from the system is retained

SI-18.2 · Data Tags Control Statement: Employ data tags to automate the correction or deletion of personally identifiable information across the information life cycle within organizational systems. Supplemental Guidance: Employ data tags to automate the correction or deletion of personally identifiable information across the information life cycle within organizational systems. Data tagging personally identifiable information includes tags that note processing permissions, authority to process, de-identification, impact level, information life cycle stage, and retention or last updated dates. Employing data tags for personally identifiable information can support the use of automation tools to correct or delete relevant personally identifiable information.

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 ADVERSARY EFFECTS 2128 P reclude (Preempt), Impede (Exert) REFERENCES Source Control: SI-14(01) 03.1 4.05E No n-Persistent Information a. [Selection (one): Refresh [Assignment: organization-defined information] [Assignment: organization-defined frequency]; Generate [Assignment: organization-defined information] on demand]. b. Delete information when no longer needed. DISCUSSION Retaining information longer than is required makes that information a potential target for

advanced adversaries searching for high value assets to compromise through unauthorized disclosure, unauthorized modification, or exfiltration. For system-related information, un

Under the FedRAMP Moderate baseline, SI-7.1 (SI-7.1 Integrity Checks): FedRAMP Moderate Baseline · SI-7.1 · Integrity Checks Control Statement: Perform an integrity check of [organization-defined parameter] [organization-defined parameter]. Supplemental Guidance: Perform an integrity check of [organization-defined parameter] [organization-defined parameter]. Security-relevant events include the identification of new threats to which organizational systems are susceptible and the installation of new hardware, software, or firmware. Transitional states include syst

Implementing 03.14.06 (03.14.06 System Monitoring) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.14.06 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.14.06 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-171 Rev 3 control 03.14.02 (03.14.02 Malicious Code Protection) falls under the System and Information Integrity family. Control Statement: SR-03.14.02.a Implement malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code. SR-03.14.02.b Update malicious code protection mechanisms as new releases are available in accordance with configuration management policies and procedures. SR-03.14.02.c Configure malicious code protection mechanisms to: SR-03.14.02.c.01 Perform scans of the system [organization-defined parameter] and real-time scans of files from external sources at endpoints or system entry and exit points as the files are downloaded, opened, or executed; and SR-03.14.02.c.02 Block malicious code, quarantine malicious code, or take other mitigation actions in response to malicious code detection. Supplemental Guidance: Malicious code insertions occur through the exploitation of system vulnerabilities. Malicious code can be inserted into the system in a variety of ways, including email, the internet, and portable storage devices. Malicious code includes viruses, worms, Trojan horses, and spyware. Malicious code can be encoded in various formats, contained in compressed or hidden files, or hidden in files using techniques such as steganography. Malicious code may be present in commercial o

NIST SP 800-53 Rev 5 control SI-12.1 (Limit Personally Identifiable Information Elements) is assessed by examining, interviewing, and testing: SI-12.1 · Limit Personally Identifiable Information Elements Control Statement: Limit personally identifiable information being processed in the information life cycle to the following elements of personally identifiable information: [organization-defined parameter]. Supplemental Guidance: Limit personally identifiable information being processed in the information life cycle to the following elements of personally identifiable information: [organization-defined parameter]. Limiting the use of

NIST SP 800-53 Rev 5 control SI-8.3 (Continuous Learning Capability) is defined as follows: SI-8.3 · Continuous Learning Capability Control Statement: Implement spam protection mechanisms with a learning capability to more effectively identify legitimate communications traffic. Supplemental Guidance: Implement spam protection mechanisms with a learning capability to more effectively identify legitimate communications traffic. Learning mechanisms include Bayesian filters that respond to user inputs that identify specific traffic as spam or legitimate by updating algorithm parameters and thereby more accurately separating types of traffic.

From the NIST SP 800-172 Rev 3 Final Public Draft: 03.14.08E Integrity Checks 2156 P erform an integrity check of [Assignment: organization-defined software, firmware, and information] [Selection (one or more): at startup; at [Assignment: organization- defined transitional states or security-relevant events]; [Assignment: organization- defined frequency]]. DISCUSSION Security-relevant events include the identification of new threats to which organizational systems are

susceptible and the installation of hardware, software, or firmware. Transitional states include system startup, restart, shutdown, and abort. This requirement is sourced to a control tailored out of the SP 800-53B [13] moderate baseline in SP 800-171. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: SI-07(0

NIST SP 800-53 Rev 5 control SI-7.5 (Automated Response to Integrity Violations) is assessed by examining, interviewing, and testing: SI-7.5 · Automated Response to Integrity Violations Control Statement: Automatically [organization-defined parameter] when integrity violations are discovered. Supplemental Guidance: Automatically [organization-defined parameter] when integrity violations are discovered. Organizations may define different integrity-checking responses by type of information, specific information, or a combination of both. Types of information include firmware, software, and user data. Specific information inclu

NIST SP 800-53 Rev 5 control SI-13.5 (Failover Capability) is assessed by examining, interviewing, and testing: SI-13.5 · Failover Capability Control Statement: Provide [organization-defined parameter] [organization-defined parameter] for the system. Supplemental Guidance: Provide [organization-defined parameter] [organization-defined parameter] for the system. Failover refers to the automatic switchover to an alternate system upon the failure of the primary system. Failover capability includes incorporating mirrored system operations at alternate processing sites or periodic data mirroring at regular i

NIST SP 800-53 Rev 5 control SI-3.4 (Updates Only by Privileged Users) is assessed by examining, interviewing, and testing: SI-3.4 · Updates Only by Privileged Users Control Statement: Update malicious code protection mechanisms only when directed by a privileged user. Supplemental Guidance: Update malicious code protection mechanisms only when directed by a privileged user. Protection mechanisms for malicious code are typically categorized as security-related software and, as such, are only updated by organizational personnel with appropriate access privileges.

From the NIST SP 800-172 Rev 3 Final Public Draft: Sou rce Control: SI-10 03.14.13E Err or Handling a. Generate error messages that provide information necessary for corrective actions without revealing information that could be exploited. b. Reveal error messages only to [Assignment: organization-defined personnel or roles]. DISCUSSION Organizations consider the structure and content of error messages. The extent to which systems can handle error conditions is guided and informed by organizational policy and operational requirements. Exploitable information includes stack traces and implementation details; erroneous logon attempts with passwords mistakenly entered as the username; mission or business information that can be derived from, if not stated explicitly by, the information recorded; and personally identifiable infor

Under the FedRAMP Low baseline, SI-4 (SI-4 System Monitoring): FedRAMP Low Baseline · SI-4 · System Monitoring Control Statement: a. Monitor the system to detect: 1. Attacks and indicators of potential attacks in accordance with the following monitoring objectives: [organization-defined parameter] ; and 2. Unauthorized local, network, and remote connections; b. Identify unauthorized use of the system through the following techniques and methods: [organization-defined parameter]; c. Invoke internal monitoring capabilities or deploy monitoring devices:

SI-14.2 · Non-persistent Information Control Statement: (a) [organization-defined parameter] ; and (b) Delete information when no longer needed. Supplemental Guidance: (a) [organization-defined parameter] ; and (b) Delete information when no longer needed. Retaining information longer than is needed makes the information a potential target for advanced adversaries searching for high value assets to compromise through unauthorized disclosure, unauthorized modification, or exfiltration. For system-related information, unnecessary retention provides advanced adversaries information that can assist in their reconnaissance and lateral movement through the system.

NIST SP 800-53 Rev 5 control SI-2.5 (Automatic Software and Firmware Updates) summarizes the requirements for this control: SI-2.5 · Automatic Software and Firmware Updates Control Statement: Install [organization-defined parameter] automatically to [organization-defined parameter]. Supplemental Guidance: Install [organization-defined parameter] automatically to [organization-defined parameter]. Due to system integrity and availability concerns, organizations consider the methodology used to carry out automatic updates. Organizations balance the need to ensure that the updates are installed as soon as possible with

NIST SP 800-53 Rev 5 control SI-4.21 (Probationary Periods) is assessed by examining, interviewing, and testing: SI-4.21 · Probationary Periods Control Statement: Implement the following additional monitoring of individuals during [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement the following additional monitoring of individuals during [organization-defined parameter]: [organization-defined parameter]. During probationary periods, employees do not have permanent employment status within organizations. Without such status or access to information that is

Under the FedRAMP High baseline, SI-11 (SI-11 Error Handling): FedRAMP High Baseline · SI-11 · Error Handling Control Statement: a. Generate error messages that provide information necessary for corrective actions without revealing information that could be exploited; and b. Reveal error messages only to [organization-defined parameter]. Supplemental Guidance: a. Generate error messages that provide information necessary for corrective actions without revealing information that could be exploited; and b. Reveal error messages only to [organization-defined

NIST SP 800-53 Rev 5 control SI-7.9 (Verify Boot Process) summarizes the requirements for this control: SI-7.9 · Verify Boot Process Control Statement: Verify the integrity of the boot process of the following system components: [organization-defined parameter]. Supplemental Guidance: Verify the integrity of the boot process of the following system components: [organization-defined parameter]. Ensuring the integrity of boot processes is critical to starting system components in known, trustworthy states. Integrity verification mechanisms provide a level of assurance that only trusted code is exe

NIST SP 800-171 Rev 3 control 03.14.03 (03.14.03 Security Alerts, Advisories, and Directives) is assessed by examining the following: Assessment Objectives: - system security alerts, advisories, and directives from external organizations are received on an ongoing basis. - internal security alerts, advisories, and directives are generated, as necessary. - internal security alerts, advisories, and directives are disseminated, as necessary.

Under the FedRAMP Moderate baseline, SI-6 (SI-6 Security and Privacy Function Verification): FedRAMP Moderate Baseline · SI-6 · Security and Privacy Function Verification Control Statement: a. Verify the correct operation of [organization-defined parameter]; b. Perform the verification of the functions specified in SI-6a [organization-defined parameter]; c. Alert [organization-defined parameter] to failed security and privacy verification tests; and d. [organization-defined parameter] when anomalies are discovered. Supplemental Guidance: a. Verify the correct operation of [organizati

NIST SP 800-53 Rev 5 control SI-5 (Security Alerts, Advisories, and Directives) is assessed by examining, interviewing, and testing: SI-5 · Security Alerts, Advisories, and Directives Control Statement: a. Receive system security alerts, advisories, and directives from [organization-defined parameter] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [organization-defined parameter] ; and d. Implement security directives in accordance with established time frames, or notify the issuing organization of the d

NIST SP 800-53 Rev 5 control SI-2.6 (Removal of Previous Versions of Software and Firmware) summarizes the requirements for this control: SI-2.6 · Removal of Previous Versions of Software and Firmware Control Statement: Remove previous versions of [organization-defined parameter] after updated versions have been installed. Supplemental Guidance: Remove previous versions of [organization-defined parameter] after updated versions have been installed. Previous versions of software or firmware components that are not removed from the system after updates have been installed may be exploited by adversaries. Some products may automati

NIST SP 800-53 Rev 5 control SI-20 (Tainting) is assessed by examining, interviewing, and testing: SI-20 · Tainting Control Statement: Embed data or capabilities in the following systems or system components to determine if organizational data has been exfiltrated or improperly removed from the organization: [organization-defined parameter]. Supplemental Guidance: Embed data or capabilities in the following systems or system components to determine if organizational data has been exfiltrated or improperly removed from the organization: [organization-defined parameter]. Many

SI-7.16 · Time Limit on Process Execution Without Supervision Control Statement: Prohibit processes from executing without supervision for more than [organization-defined parameter]. Supplemental Guidance: Prohibit processes from executing without supervision for more than [organization-defined parameter]. Placing a time limit on process execution without supervision is intended to apply to processes for which typical or normal execution periods can be determined and situations in which organizations exceed such periods. Supervision includes timers on operating systems, automated responses, and manual oversight and response when system process anomalies occur.

NIST SP 800-53 Rev 5 control SI-13 (Predictable Failure Prevention) summarizes the requirements for this control: SI-13 · Predictable Failure Prevention Control Statement: a. Determine mean time to failure (MTTF) for the following system components in specific environments of operation: [organization-defined parameter] ; and b. Provide substitute system components and a means to exchange active and standby components in accordance with the following criteria: [organization-defined parameter]. Supplemental Guidance: a. Determine mean time to failure (MTTF) for the following system components in specific en

SI-19.1 · Collection Control Statement: De-identify the dataset upon collection by not collecting personally identifiable information. Supplemental Guidance: De-identify the dataset upon collection by not collecting personally identifiable information. If a data source contains personally identifiable information but the information will not be used, the dataset can be de-identified when it is created by not collecting the data elements that contain the personally identifiable information. For example, if an organization does not intend to use the social security number of an applicant, then application forms do not ask for a social security number.

NIST SP 800-53 Rev 5 control SI-4.16 (Correlate Monitoring Information) is assessed by examining, interviewing, and testing: SI-4.16 · Correlate Monitoring Information Control Statement: Correlate information from monitoring tools and mechanisms employed throughout the system. Supplemental Guidance: Correlate information from monitoring tools and mechanisms employed throughout the system. Correlating information from different system monitoring tools and mechanisms can provide a more comprehensive view of system activity. Correlating system monitoring tools and mechanisms that typically work in isolation-including m

NIST SP 800-53 Rev 5 control SI-13.1 (Transferring Component Responsibilities) summarizes the requirements for this control: SI-13.1 · Transferring Component Responsibilities Control Statement: Take system components out of service by transferring component responsibilities to substitute components no later than [organization-defined parameter] of mean time to failure. Supplemental Guidance: Take system components out of service by transferring component responsibilities to substitute components no later than [organization-defined parameter] of mean time to failure. Transferring primary system component responsibili

NIST SP 800-171 Rev 3 control 03.14.02 (03.14.02 Malicious Code Protection) is assessed by examining the following: Assessment Objectives: - malicious code protection mechanisms are implemented at system entry and exit points to detect malicious code. - malicious code protection mechanisms are implemented at system entry and exit points to eradicate malicious code. - malicious code protection mechanisms are updated as new releases are available in accordance with configuration management policy and procedures. - malicious code protection mechanisms are configured to perform scans of the system [organization-defined parameter]. - malicious code protection mechanisms are configured to block malicious code, qu

NIST SP 800-53 Rev 5 control SI-13.4 (Standby Component Installation and Notification) is assessed by examining, interviewing, and testing: SI-13.4 · Standby Component Installation and Notification Control Statement: If system component failures are detected: (a) Ensure that the standby components are successfully and transparently installed within [organization-defined parameter] ; and (b) [organization-defined parameter]. Supplemental Guidance: If system component failures are detected: (a) Ensure that the standby components are successfully and transparently installed within [organization-defined parameter] ; and (b) [organizat

NIST SP 800-53 Rev 5 control SI-18.2 (Data Tags) summarizes the requirements for this control:

SI-18.2 · Data Tags Control Statement: Employ data tags to automate the correction or deletion of personally identifiable information across the information life cycle within organizational systems. Supplemental Guidance: Employ data tags to automate the correction or deletion of personally identifiable information across the information life cycle within organizational systems. Data tagging personally identifiable information includes tags that note processing permissions, authority to process

Under the FedRAMP Moderate baseline, SI-4.18 (SI-4.18 Analyze Traffic and Covert Exfiltration): FedRAMP Moderate Baseline · SI-4.18 · Analyze Traffic and Covert Exfiltration Control Statement: Analyze outbound communications traffic at external interfaces to the system and at the following interior points to detect covert exfiltration of information: [organization-defined parameter]. Supplemental Guidance: Analyze outbound communications traffic at external interfaces to the system and at the following interior points to detect covert exfiltration of information: [organization-defined parameter]

NIST SP 800-53 Rev 5 control SI-17 (Fail-safe Procedures) is assessed by examining, interviewing, and testing: SI-17 · Fail-safe Procedures Control Statement: Implement the indicated fail-safe procedures when the indicated failures occur: [organization-defined parameter]. Supplemental Guidance: Implement the indicated fail-safe procedures when the indicated failures occur: [organization-defined parameter]. Failure conditions include the loss of communications among critical system components or between system components and operational facilities. Fail-safe procedures include alerting operator personnel

NIST SP 800-53 Rev 5 control SI-19.3 (Release) summarizes the requirements for this control: SI-19.3 · Release Control Statement: Remove personally identifiable information elements from a dataset prior to its release if those elements in the dataset do not need to be part of the data release. Supplemental Guidance: Remove personally identifiable information elements from a dataset prior to its release if those elements in the dataset do not need to be part of the data release. Prior to releasing a dataset, a data custodian considers the intended uses of the dataset and determines if

Under the FedRAMP Moderate baseline, SI-4.23 (SI-4.23 Host-based Devices): FedRAMP Moderate Baseline · SI-4.23 · Host-based Devices Control Statement: Implement the following host-based monitoring mechanisms at [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement the following host-based monitoring mechanisms at [organization-defined parameter]: [organization-defined parameter]. Host-based monitoring collects information about the host (or system in which it resides). System components in which host-based monitoring can

NIST SP 800-53 Rev 5 control SI-4.23 (Host-based Devices) summarizes the requirements for this control: SI-4.23 · Host-based Devices Control Statement: Implement the following host-based monitoring mechanisms at [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement the following host-based monitoring mechanisms at [organization-defined parameter]: [organization-defined parameter]. Host-based monitoring collects information about the host (or system in which it resides). System components in which host-based monitoring can be implemented include serv

NIST SP 800-171 Rev 3 control 03.14.06 (03.14.06 System Monitoring) falls under the System and Information Integrity family. Control Statement: SR-03.14.06.a Monitor the system to detect: SR-03.14.06.a.01 Attacks and indicators of potential attacks and SR-03.14.06.a.02 Unauthorized connections. SR-03.14.06.b Identify unauthorized use of the system. SR-03.14.06.c Monitor inbound and outbound communications traffic to detect unusual or unauthorized activities or conditions. Supplemental Guidance: System monitoring involves external and internal monitoring. Internal monitoring includes the observation of events that occur within the system. External monitoring includes the observation of events that occur at the system boundary. Organizations can monitor the system by observing audit record activities in real time or by observing other system aspects, such as access patterns, characteristics of access, and other actions. The monitoring objectives may guide determina

NIST SP 800-53 Rev 5 control SI-6 (Security and Privacy Function Verification) is defined as follows: SI-6 · Security and Privacy Function Verification Control Statement: a. Verify the

correct operation of [organization-defined parameter]; b. Perform the verification of the functions specified in SI-6a [organization-defined parameter]; c. Alert [organization-defined parameter] to failed security and privacy verification tests; and d. [organization-defined parameter] when anomalies are discovered. Supplemental Guidance: a. Verify the correct operation of [organization-defined parameter]; b. Perform the verification of the functions specified in SI-6a [organization-defined parameter]; c. Alert

NIST SP 800-53 Rev 5 control SI-4 (System Monitoring) is assessed by examining, interviewing, and testing: SI-4 · System Monitoring Control Statement: a. Monitor the system to detect: 1. Attacks and indicators of potential attacks in accordance with the following monitoring objectives: [organization-defined parameter] ; and 2. Unauthorized local, network, and remote connections; b. Identify unauthorized use of the system through the following techniques and methods: [organization-defined parameter]; c. Invoke internal monitoring capabilities or deploy monitoring devices: 1. Strategically with

NIST SP 800-53 Rev 5 control SI-7 (Software, Firmware, and Information Integrity) is defined as follows: SI-7 · Software, Firmware, and Information Integrity Control Statement: a. Employ integrity verification tools to detect unauthorized changes to the following software, firmware, and information: [organization-defined parameter] ; and b. Take the following actions when unauthorized changes to the software, firmware, and information are detected: [organization-defined parameter]. Supplemental Guidance: a. Employ integrity verification tools to detect unauthorized changes to the following software, firmware, and information: [organization-defined parameter] ; and b. Take the following actions

NIST SP 800-53 Rev 5 control SI-4.12 (Automated Organization-generated Alerts) is defined as follows: SI-4.12 · Automated Organization-generated Alerts Control Statement: Alert [organization-defined parameter] using [organization-defined parameter] when the following indications of inappropriate or unusual activities with security or privacy implications occur: [organization-defined parameter]. Supplemental Guidance: Alert [organization-defined parameter] using [organization-defined parameter] when the following indications of inappropriate or unusual activities with security or privacy implications occur: [organization-defined parameter]. Organizational personnel on the system alert notific

FedRAMP High Baseline · SI-5 · Security Alerts, Advisories, and Directives Control Statement: a. Receive system security alerts, advisories, and directives from [organization-defined parameter] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [organization-defined parameter] ; and d. Implement security directives in accordance with established time frames, or notify the issuing organization of the degree of noncompliance. Requirement: Service Providers must address the CISA Emergency and Binding Operational Directives applicable to their cloud service offering per FedRAMP guidance. This includes listing the applicable directives and stating compliance status. Supplemental Guidance: a. Receive system security alerts, advisories, and directives from [organization-defined parameter] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [organization-defined parameter] ; and d. Implement security directives in accordance with established time frames, or notify the issuing organization of the degree of noncompliance. Requirement: Service Providers must address the CISA Emergency and Binding Operational Directives applicable to their cloud service offering per FedRAMP guidance. This includes listing the applicable directives and stating compliance status. The Cybersecurity and Infrastructure Security Agency (CISA) generates security alerts and advisories to maintain situational awareness throughout the Federal Government. Security directives are issued by OMB or other designated organizations with the responsibility and authority to issue such directives. Compliance with security directives is essential due to the critical nature of many of these directives and the potential (immediate) adverse effects on organizational operations and assets, individuals, other organizations, and the Nation should the directives not be implemented in a timely manner. External organizations include supply chain partners, external mission or business partners, external service providers, and other peer or supporting organizations. Assessment Objectives: a. Receive system security alerts, advisories, and directives from [organization-defined parameter] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [organization-

defined parameter] ; and d. Implement security directives in accordance with established time frames, or notify the issuing organization of the degree of noncompliance. Requirement: Service Providers must address the CISA Emergency and Binding Operational Directives applicable to their cloud service offering per FedRAMP guidance. This includes listing the applicable directives and stating compliance status. FedRAMP Parameter Values: si-05_odp.01: to include US-CERT and Cybersecurity and Infrastructure Security Agency (CISA) Directives si-05_odp.02: to include system security personnel and administrators with configuration/patch-management responsibilities si-05_odp.03: personnel or roles to whom security alerts, advisories, and directives are to be disseminated is/are defined (if selected); si-05_odp.04: elements within the organization to whom security alerts, advisories, and directives are to be disseminated are defined (if selected); si-05_odp.05: external organizations to whom security alerts, advisories, and directives are to be disseminated are defined (if selected);

NIST SP 800-53 Rev 5 control SI-4.18 (Analyze Traffic and Covert Exfiltration) is assessed by examining, interviewing, and testing: SI-4.18 · Analyze Traffic and Covert Exfiltration Control Statement: Analyze outbound communications traffic at external interfaces to the system and at the following interior points to detect covert exfiltration of information: [organization-defined parameter]. Supplemental Guidance: Analyze outbound communications traffic at external interfaces to the system and at the following interior points to detect covert exfiltration of information: [organization-defined parameter]. Organization-defin

NIST SP 800-171 Rev 3 control 03.14.02 (03.14.02 Malicious Code Protection) requires organizations to implement the following: Control Statement: SR-03.14.02.a Implement malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code. SR-03.14.02.b Update malicious code protection mechanisms as new releases are available in accordance with configuration management policies and procedures. SR-03.14.02.c Configure malicious code protection mechanisms to: SR-03.14.02.c.01 Perform scans of the system [organization-defined parameter] and real-time scans of files from external sources at endpoints or system entry and exit points as the files are downloaded, opened, or executed; and SR-03.14.02.c.02 Block malicious code, quarantine malicious code, or take other mitigation actions in response to malicious code detection. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.14.02.

SI-19.4 · Removal, Masking, Encryption, Hashing, or Replacement of Direct Identifiers Control Statement: Remove, mask, encrypt, hash, or replace direct identifiers in a dataset. Supplemental Guidance: Remove, mask, encrypt, hash, or replace direct identifiers in a dataset. There are many possible processes for removing direct identifiers from a dataset. Columns in a dataset that contain a direct identifier can be removed. In masking, the direct identifier is transformed into a repeating character, such as XXXXXX or 999999. Identifiers can be encrypted or hashed so that the linked records remain linked. In the case of encryption or hashing, algorithms are employed that require the use of a key, including the Advanced Encryption Standard or a Hash-based Message Authentication Code. Implementations may use the same key for all identifiers or use a different key for each identifier. Using a different key for each identifier provides a higher degree of security and privacy. Identifiers can alternatively be replaced with a keyword, including transforming "George Washington" to "PATIENT" or replacing it with a surrogate value, such as transforming "George Washington" to "Abraham Polk."

NIST SP 800-53 Rev 5 control SI-16 (Memory Protection) is assessed by examining, interviewing, and testing: SI-16 · Memory Protection Control Statement: Implement the following controls to protect the system memory from unauthorized code execution: [organization-defined parameter]. Supplemental Guidance: Implement the following controls to protect the system memory from unauthorized code execution: [organization-defined parameter]. Some adversaries launch attacks with the intent of executing code in non-executable regions of memory or in memory locations that are prohibited. Controls employed to pro

From the NIST SP 800-172 Rev 3 Final Public Draft: Organization-generated alerts are focused on information sources that are external 2391 to the system, such as suspicious activity reports and reports on potential insider threats. Organizational personnel on the system alert notification list include system administrators, mission or business owners, system owners, chief information

security officers, and system security officers. This requirement enhances SP 800-171 requirement 3.14.06. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Expose (Detect) REFERENCES Source Controls: SI-04(12) 3.15. Planning 3.15.01 E Security Architecture a. Develop a security architecture for the system that: 1. Describes the security requirements and approach to be taken for protecting the confidentiality, integrity, and availability of CUI,

NIST SP 800-53 Rev 5 control SI-19.1 (Collection) summarizes the requirements for this control: SI-19.1 · Collection Control Statement: De-identify the dataset upon collection by not collecting personally identifiable information. Supplemental Guidance: De-identify the dataset upon collection by not collecting personally identifiable information. If a data source contains personally identifiable information but the information will not be used, the dataset can be de-identified when it is created by not collecting the data elements that contain the personally identifiable information. For

Under the FedRAMP High baseline, SI-5.1 (SI-5.1 Automated Alerts and Advisories): FedRAMP High Baseline · SI-5.1 · Automated Alerts and Advisories Control Statement: Broadcast security alert and advisory information throughout the organization using [organization-defined parameter]. Supplemental Guidance: Broadcast security alert and advisory information throughout the organization using [organization-defined parameter]. The significant number of changes to organizational systems and environments of operation requires the dissemination of security-related information to a v

NIST SP 800-53 Rev 5 control SI-10.6 (Injection Prevention) summarizes the requirements for this control: SI-10.6 · Injection Prevention Control Statement: Prevent untrusted data injections. Supplemental Guidance: Prevent untrusted data injections. Untrusted data injections may be prevented using a parameterized interface or output escaping (output encoding). Parameterized interfaces separate data from code so that injections of malicious or unintended data cannot change the semantics of commands being sent. Output escaping uses specified characters to inform the interpreter's parser whether data

NIST SP 800-53 Rev 5 control SI-20 (Tainting) summarizes the requirements for this control: SI-20 · Tainting Control Statement: Embed data or capabilities in the following systems or system components to determine if organizational data has been exfiltrated or improperly removed from the organization: [organization-defined parameter]. Supplemental Guidance: Embed data or capabilities in the following systems or system components to determine if organizational data has been exfiltrated or improperly removed from the organization: [organization-defined parameter]. Many cyber-attacks ta

NIST SP 800-53 Rev 5 control SI-4.15 (Wireless to Wireline Communications) is assessed by examining, interviewing, and testing: SI-4.15 · Wireless to Wireline Communications Control Statement: Employ an intrusion detection system to monitor wireless communications traffic as the traffic passes from wireless to wireline networks. Supplemental Guidance: Employ an intrusion detection system to monitor wireless communications traffic as the traffic passes from wireless to wireline networks. Wireless networks are inherently less secure than wired networks. For example, wireless networks are more susceptible to eavesdroppers

FedRAMP High Baseline · SI-4.4 · Inbound and Outbound Communications Traffic Control Statement: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic; (b) Monitor inbound and outbound communications traffic [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic; (b) Monitor inbound and outbound communications traffic [organization-defined parameter] for [organization-defined parameter]. Unusual or unauthorized activities or conditions related to system inbound and outbound communications traffic includes internal traffic that indicates the presence of malicious code or unauthorized use of legitimate code or credentials within organizational systems or propagating among system components, signaling to external systems, and the unauthorized exporting of information. Evidence of malicious code or unauthorized use of legitimate code or credentials is used to identify potentially compromised systems or system components. Assessment Objectives: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic; (b) Monitor inbound and outbound communications traffic [organization-defined parameter] for [organization-defined parameter].

FedRAMP Parameter Values: si-4.4_prm_1: continuously si-4.4_prm_2: organization-defined unusual or unauthorized activities or conditions si-04.04_odp.01: the frequency at which to monitor inbound communications traffic for unusual or unauthorized activities or conditions is defined; si-04.04_odp.02: unusual or unauthorized activities or conditions that are to be monitored in inbound communications traffic are defined; si-04.04_odp.03: the frequency at which to monitor outbound communications traffic for unusual or unauthorized activities or conditions is defined; si-04.04_odp.04: unusual or unauthorized activities or conditions that are to be monitored in outbound communications traffic are defined;

Under the FedRAMP Low baseline, SI-1 (SI-1 Policy and Procedures): FedRAMP Low Baseline · SI-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] system and information integrity policy that: 2. Procedures to facilitate the implementation of the system and information integrity policy and the associated system and information integrity controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination o

NIST SP 800-53 Rev 5 control SI-4.14 (Wireless Intrusion Detection) summarizes the requirements for this control: SI-4.14 · Wireless Intrusion Detection Control Statement: Employ a wireless intrusion detection system to identify rogue wireless devices and to detect attack attempts and potential compromises or breaches to the system. Supplemental Guidance: Employ a wireless intrusion detection system to identify rogue wireless devices and to detect attack attempts and potential compromises or breaches to the system. Wireless signals may radiate beyond organizational facilities. Organizations proactively se

NIST SP 800-53 Rev 5 control SI-19.3 (Release) is assessed by examining, interviewing, and testing: SI-19.3 · Release Control Statement: Remove personally identifiable information elements from a dataset prior to its release if those elements in the dataset do not need to be part of the data release. Supplemental Guidance: Remove personally identifiable information elements from a dataset prior to its release if those elements in the dataset do not need to be part of the data release. Prior to releasing a dataset, a data custodian considers the intended uses of the dataset and determines if

Under the FedRAMP High baseline, SI-7.15 (SI-7.15 Code Authentication): FedRAMP High Baseline · SI-7.15 · Code Authentication Control Statement: Implement cryptographic mechanisms to authenticate the following software or firmware components prior to installation: [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to authenticate the following software or firmware components prior to installation: [organization-defined parameter]. Cryptographic authentication includes verifying that software or firmware components have been

SI-20 · Tainting Control Statement: Embed data or capabilities in the following systems or system components to determine if organizational data has been exfiltrated or improperly removed from the organization: [organization-defined parameter]. Supplemental Guidance: Embed data or capabilities in the following systems or system components to determine if organizational data has been exfiltrated or improperly removed from the organization: [organization-defined parameter]. Many cyber-attacks target organizational information, or information that the organization holds on behalf of other entities (e.g., personally identifiable information), and exfiltrate that data. In addition, insider attacks and erroneous user procedures can remove information from the system that is in violation of the organizational policies. Tainting approaches can range from passive to active. A passive tainting approach can be as simple as adding false email names and addresses to an internal database. If the organization receives email at one of the false email addresses, it knows that the database has been compromised. Moreover, the organization knows that the email was sent by an unauthorized entity, so any packets it includes potentially contain malicious code, and that the unauthorized entity may have potentially obtained a copy of the database. Another tainting approach can include embedding false data or steganographic data in files to enable the data to be found via open-source analysis. Finally, an active tainting approach can include embedding software in the data that is able to "call home," thereby alerting the organization to its "capture," and possibly its location, and the path by which it was exfiltrated or removed.

NIST SP 800-53 Rev 5 control SI-7.1 (Integrity Checks) summarizes the requirements for this control: SI-7.1 · Integrity Checks Control Statement: Perform an integrity check of [organization-defined

parameter] [organization-defined parameter]. Supplemental Guidance: Perform an integrity check of [organization-defined parameter] [organization-defined parameter]. Security-relevant events include the identification of new threats to which organizational systems are susceptible and the installation of new hardware, software, or firmware. Transitional states include system startup, restart, shutdown

NIST SP 800-53 Rev 5 control SI-7.15 (Code Authentication) summarizes the requirements for this control: SI-7.15 · Code Authentication Control Statement: Implement cryptographic mechanisms to authenticate the following software or firmware components prior to installation: [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to authenticate the following software or firmware components prior to installation: [organization-defined parameter]. Cryptographic authentication includes verifying that software or firmware components have been digitally signed using

SI-4.19 · Risk for Individuals Control Statement: Implement [organization-defined parameter] of individuals who have been identified by [organization-defined parameter] as posing an increased level of risk. Supplemental Guidance: Implement [organization-defined parameter] of individuals who have been identified by [organization-defined parameter] as posing an increased level of risk. Indications of increased risk from individuals can be obtained from different sources, including personnel records, intelligence agencies, law enforcement organizations, and other sources. The monitoring of individuals is coordinated with the management, legal, security, privacy, and human resource officials who conduct such monitoring. Monitoring is conducted in accordance with applicable laws, executive orders, directives, regulations, policies, standards, and guidelines.

NIST SP 800-53 Rev 5 control SI-5.1 (Automated Alerts and Advisories) is assessed by examining, interviewing, and testing: SI-5.1 · Automated Alerts and Advisories Control Statement: Broadcast security alert and advisory information throughout the organization using [organization-defined parameter]. Supplemental Guidance: Broadcast security alert and advisory information throughout the organization using [organization-defined parameter]. The significant number of changes to organizational systems and environments of operation requires the dissemination of security-related information to a variety of organizational

NIST SP 800-53 Rev 5 control SI-4.4 (Inbound and Outbound Communications Traffic) is assessed by examining, interviewing, and testing: SI-4.4 · Inbound and Outbound Communications Traffic Control Statement: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic; (b) Monitor inbound and outbound communications traffic [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic; (b) Monitor inbound and ou

Under the FedRAMP High baseline, SI-8.2 (SI-8.2 Automatic Updates): FedRAMP High Baseline · SI-8.2 · Automatic Updates Control Statement: Automatically update spam protection mechanisms [organization-defined parameter]. Supplemental Guidance: Automatically update spam protection mechanisms [organization-defined parameter]. Using automated mechanisms to update spam protection mechanisms helps to ensure that updates occur on a regular basis and provide the latest content and protection capabilities. Assessment Objectives: Automatically update spam protection me

NIST SP 800-53 Rev 5 control SI-7.2 (Automated Notifications of Integrity Violations) summarizes the requirements for this control: SI-7.2 · Automated Notifications of Integrity Violations Control Statement: Employ automated tools that provide notification to [organization-defined parameter] upon discovering discrepancies during integrity verification. Supplemental Guidance: Employ automated tools that provide notification to [organization-defined parameter] upon discovering discrepancies during integrity verification. The employment of automated tools to report system and information integrity violations and to notify org

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: System and Information Integrity 3.14.1 System Flaw Remediation a. Identify, report, and correct system flaws. b. Install security-relevant software and firmware updates within [Assignment: organization-defined time period] (03.14.01.b) of the release of the updates. Related Controls: SI-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.14.01.b [Assignment: organization-defined time period] thirty

(30) days for high-risk flaws (including both critical and high), 90 days for moderate-risk flaws, and 180 days for low-risk flaws System and Information Integrity 3.14.2 Malicious Code Protection
a. Implement malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code. b. Update malicious code protection mechanisms a

NIST SP 800-53 Rev 5 control SI-7.12 (Integrity Verification): SI-7.12 · Integrity Verification
Control Statement: Require that the integrity of the following user-installed software be verified prior to execution: [organization-defined parameter]. Supplemental Guidance: Require that the integrity of the following user-installed software be verified prior to execution: [organization-defined parameter]. Organizations verify the integrity of user-installed so

NIST SP 800-53 Rev 5 control SI-18.5 (Notice of Correction or Deletion) is defined as follows:
SI-18.5 · Notice of Correction or Deletion Control Statement: Notify [organization-defined parameter] and individuals that the personally identifiable information has been corrected or deleted. Supplemental Guidance: Notify [organization-defined parameter] and individuals that the personally identifiable information has been corrected or deleted. When personally identifiable information is corrected or deleted, organizations take steps to ensure that all authorized recipients of such information, and the individual with whom the information is associated or their designated representatives,

NIST SP 800-171 Rev 3 control 03.14.03 (03.14.03 Security Alerts, Advisories, and Directives) falls under the System and Information Integrity family. Control Statement: SR-03.14.03.a Receive system security alerts, advisories, and directives from external organizations on an ongoing basis. SR-03.14.03.b Generate and disseminate internal system security alerts, advisories, and directives, as necessary. Supplemental Guidance: There are many publicly available sources of system security alerts and advisories. The Department of Homeland Security's Cybersecurity and Infrastructure Security Agency (CISA), the National Security Agency (NSA), and the Federal Bureau of Investigation (FBI) generate security alerts and advisories to maintain situational awareness across the Federal Government and in nonfederal organizations. Software vendors, subscription services, and industry Information Sharing and A

NIST SP 800-53 Rev 5 control SI-2 (Flaw Remediation) is assessed by examining, interviewing, and testing: SI-2 · Flaw Remediation Control Statement: a. Identify, report, and correct system flaws; b. Test software and firmware updates related to flaw remediation for effectiveness and potential side effects before installation; c. Install security-relevant software and firmware updates within [organization-defined parameter] of the release of the updates; and d. Incorporate flaw remediation into the organizational configuration management process. Supplemental Guidance: a. Identify, report, and corr

From the NIST SP 800-172 Rev 3 Final Public Draft: ADVERSARY EFFECTS 2359 Ex pose (Detect) REFERENCES Source Control: SI-20 03.14.17 E Sys tem-Generated Alerts Alert [Assignment: organization-defined personnel or roles] when the following system-generated indications of compromise or potential compromise occur: [Assignment: organization-defined compromise indicators]. DISCUSSION Alerts may be generated from different sources internal to the system, including audit records, inputs from malicious code protection mechanisms, intrusion detection or prevention mechanisms, or boundary protection devices such as firewalls, gateways, and routers. Compromise indicators could include CUI being accessed by unauthorized users or when CUI traverses architecture outside of defined data flows. Alerts can be automated and transmitted telepho

From the NIST SP 800-172 Rev 3 Final Public Draft: The refresh of selected system components 2323 and services occurs with sufficient frequency to prevent the spread or intended i mpact of attacks but not with such frequency that it makes the system unstable. This requirement does not enhance a specific requirement in SP 800-171 but can be used to strengthen the protection of CUI associated with critical programs or high value assets. PROTECTION STRATEGY PRA, CRS ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Limit (Shorten, Reduce) REFERENCES Source Control: SI-14 03.14.16 E Ta inting Embed data or capabilities in the following systems or system components to determine if CUI has been exfiltrated or improperly removed from the organization: [Assignment: organization-defined systems or system components]. DISCUSSION

NIST SP 800-53 Rev 5 control SI-4.15 (Wireless to Wireline Communications) summarizes the

requirements for this control: SI-4.15 · Wireless to Wireline Communications Control Statement: Employ an intrusion detection system to monitor wireless communications traffic as the traffic passes from wireless to wireline networks. Supplemental Guidance: Employ an intrusion detection system to monitor wireless communications traffic as the traffic passes from wireless to wireline networks. Wireless networks are inherently less secure than wired networks. For example, wireless networks are more susceptible to eavesdroppers

NIST SP 800-171 Rev 3 control 03.14.03 (03.14.03 Security Alerts, Advisories, and Directives) is assessed by examining the following: Assessment Objectives: - system security alerts, advisories, and directives from external organizations are received on an ongoing basis. - internal security alerts, advisories, and directives are generated, as necessary. - internal security alerts, advisories, and directives are disseminated, as necessary.

SI-7.1 · Integrity Checks Control Statement: Perform an integrity check of [organization-defined parameter] [organization-defined parameter]. Supplemental Guidance: Perform an integrity check of [organization-defined parameter] [organization-defined parameter]. Security-relevant events include the identification of new threats to which organizational systems are susceptible and the installation of new hardware, software, or firmware. Transitional states include system startup, restart, shutdown, and abort.

NIST SP 800-53 Rev 5 control SI-7.8 (Auditing Capability for Significant Events) is defined as follows: SI-7.8 · Auditing Capability for Significant Events Control Statement: Upon detection of a potential integrity violation, provide the capability to audit the event and initiate the following actions: [organization-defined parameter]. Supplemental Guidance: Upon detection of a potential integrity violation, provide the capability to audit the event and initiate the following actions: [organization-defined parameter]. Organizations select response actions based on types of software, specific software, or information for which there are potential integrity violations.

Control PT-3: s i p u b l i c a t i o n i s a v a i l a b e f r e e o f c h a r g e f r o m : h t
t p s : / / d o i . o r g / 1 0 . 6 0 2 8 / N S T S P . 8 0 0 - 5 3 r 5 . I NIST SP 800-53, REV. 5
SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Control Enhancements: (1) PERSONALLY IDENTIFIABLE INFORMATION PROCESSING PURPOSES | DATA TAGGING Attach data tags containing the following purposes to [Assignment: organization-defined elements of personally identifiable information]: [Assignment: organization-defined processing purposes]. Discussion: Data tags support the tracking of processing purposes by conveying the purposes along with the relevant elements of personally identifiable information throughout the system. By conveying the processing purposes in a data tag along with the personally identifiable information as the information transits a system, a system owner or operator can identify whether a change in processing would be compatible with the identified and documented purposes. Data tags may also support the use of automated tools. Related Controls: CA-6, CM-12, PM-5, PM-22, SC-16, SC-43, SI-10, SI-15, SI-19. (2) PERSONALLY IDENTIFIABLE INFORMATION PROCESSING PURPOSES | AUTOMATION Track processing purposes of personally identifiable information using [Assignment: organization-defined automated mechanisms]. Discussion: Automated mechanisms augment tracking of the processing purposes. Related Controls: CA-6, CM-12, PM-5, PM-22, SC-16, SC-43, SI-10, SI-15, SI-19. References: [PRIVACT], [OMB A-130], [IR 8112].

NIST SP 800-53 Rev 5 control SI-19.2 (Archiving): SI-19.2 · Archiving Control Statement: Prohibit archiving of personally identifiable information elements if those elements in a dataset will not be needed after the dataset is archived. Supplemental Guidance: Prohibit archiving of personally identifiable information elements if those elements in a dataset will not be needed after the dataset is archived. Datasets can be archived for many reason

NIST SP 800-53 Rev 5 control SI-2.5 (Automatic Software and Firmware Updates) is defined as follows: SI-2.5 · Automatic Software and Firmware Updates Control Statement: Install [organization-defined parameter] automatically to [organization-defined parameter]. Supplemental Guidance: Install [organization-defined parameter] automatically to [organization-defined parameter]. Due to system integrity and availability concerns, organizations consider the methodology used to carry out automatic updates. Organizations balance the need to ensure that the updates are installed as soon as possible with the need to maintain configuration management and control with any mission or

operational impacts t

Under the FedRAMP Low baseline, SI-5 (SI-5 Security Alerts, Advisories, and Directives): FedRAMP Low Baseline · SI-5 · Security Alerts, Advisories, and Directives Control Statement: a. Receive system security alerts, advisories, and directives from [organization-defined parameter] on an ongoing basis; b. Generate internal security alerts, advisories, and directives as deemed necessary; c. Disseminate security alerts, advisories, and directives to: [organization-defined parameter] ; and d. Implement security directives in accordance with established time frames, or notify the issuin

Under the FedRAMP Moderate baseline, SI-4.2 (SI-4.2 Automated Tools and Mechanisms for Real-time Analysis): FedRAMP Moderate Baseline · SI-4.2 · Automated Tools and Mechanisms for Real-time Analysis Control Statement: Employ automated tools and mechanisms to support near real-time analysis of events. Supplemental Guidance: Employ automated tools and mechanisms to support near real-time analysis of events. Automated tools and mechanisms include host-based, network-based, transport-based, or storage-based event monitoring tools and mechanisms or security information and event management (SIEM) technol

NIST SP 800-53 Rev 5 control SI-4.16 (Correlate Monitoring Information): SI-4.16 · Correlate Monitoring Information Control Statement: Correlate information from monitoring tools and mechanisms employed throughout the system. Supplemental Guidance: Correlate information from monitoring tools and mechanisms employed throughout the system. Correlating information from different system monitoring tools and mechanisms can provide a more comprehensive view of system activ

NIST SP 800-53 Rev 5 control SI-13.3 (Manual Transfer Between Components) summarizes the requirements for this control: SI-13.3 · Manual Transfer Between Components Control Statement: Manually initiate transfers between active and standby system components when the use of the active component reaches [organization-defined parameter] of the mean time to failure. Supplemental Guidance: Manually initiate transfers between active and standby system components when the use of the active component reaches [organization-defined parameter] of the mean time to failure. For example, if the MTTF for a system component is

NIST SP 800-53 Rev 5 control SI-22 (Information Diversity) is defined as follows: SI-22 · Information Diversity Control Statement: a. Identify the following alternative sources of information for [organization-defined parameter]: [organization-defined parameter] ; and b. Use an alternative information source for the execution of essential functions or services on [organization-defined parameter] when the primary source of information is corrupted or unavailable. Supplemental Guidance: a. Identify the following alternative sources of information for [organization-defined parameter]: [organization-defined parameter] ; and b. Use an alternative information source for the exe

NIST SP 800-53 Rev 5 control SI-4.20 (Privileged Users) is assessed by examining, interviewing, and testing: SI-4.20 · Privileged Users Control Statement: Implement the following additional monitoring of privileged users: [organization-defined parameter]. Supplemental Guidance: Implement the following additional monitoring of privileged users: [organization-defined parameter]. Privileged users have access to more sensitive information, including security-related information, than the general user population. Access to such information means that privileged users can potentially do greater damage to s

NIST SP 800-171 Rev 3 control 03.14.08 (03.14.08 Information Management and Retention) falls under the System and Information Integrity family. 03.14.08 · Information Management and Retention Supplemental Guidance: Federal agencies consider data retention requirements for nonfederal organizations. Retaining CUI on nonfederal systems after contracts or agreements have concluded increases the attack surface for those systems and the risk of the information being compromised. NARA provides federal policy and guidance on records retention and schedules. Assessment Objectives: - CUI within the system is managed in accordance with applicabl Supplemental Guidance: Federal agencies consider data retention requirements for nonfederal organizations. Retaining CUI on nonfederal systems after contracts or agreements have concluded increases the attack surface for those systems and the risk of the information being compromised. NARA provides federal policy and

guidance on records retention and schedules.

NIST SP 800-53 Rev 5 control SI-3 (Malicious Code Protection) is assessed by examining, interviewing, and testing: SI-3 · Malicious Code Protection Control Statement: a. Implement [organization-defined parameter] malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code; b. Automatically update malicious code protection mechanisms as new releases are available in accordance with organizational configuration management policy and procedures; c. Configure malicious code protection mechanisms to: 1. Perform periodic scans of the system [organization-defined p

NIST SP 800-171 Rev 3 control 03.14.01 (03.14.01 Flaw Remediation) is assessed by examining the following: Assessment Objectives: - system flaws are identified. - system flaws are reported. - system flaws are corrected. - security-relevant software updates are installed within [organization-defined parameter] of the release of the updates. - security-relevant firmware updates are installed within [organization-defined parameter] of the release of the updates.

NIST SP 800-53 Rev 5 control SI-2 (Flaw Remediation) summarizes the requirements for this control: SI-2 · Flaw Remediation Control Statement: a. Identify, report, and correct system flaws; b. Test software and firmware updates related to flaw remediation for effectiveness and potential side effects before installation; c. Install security-relevant software and firmware updates within [organization-defined parameter] of the release of the updates; and d. Incorporate flaw remediation into the organizational configuration management process. Supplemental Guidance: a. Identify, report, and corr

Under the FedRAMP High baseline, SI-1 (SI-1 Policy and Procedures): FedRAMP High Baseline · SI-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] system and information integrity policy that: 2. Procedures to facilitate the implementation of the system and information integrity policy and the associated system and information integrity controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination

NIST SP 800-53 Rev 5 control SI-14.1 (Refresh from Trusted Sources) is assessed by examining, interviewing, and testing: SI-14.1 · Refresh from Trusted Sources Control Statement: Obtain software and data employed during system component and service refreshes from the following trusted sources: [organization-defined parameter]. Supplemental Guidance: Obtain software and data employed during system component and service refreshes from the following trusted sources: [organization-defined parameter]. Trusted sources include software and data from write-once, read-only media or from selected offline secure storage fa

FedRAMP High Baseline · SI-4.12 · Automated Organization-generated Alerts Control Statement: Alert [organization-defined parameter] using [organization-defined parameter] when the following indications of inappropriate or unusual activities with security or privacy implications occur: [organization-defined parameter]. Supplemental Guidance: Alert [organization-defined parameter] using [organization-defined parameter] when the following indications of inappropriate or unusual activities with security or privacy implications occur: [organization-defined parameter]. Organizational personnel on the system alert notification list include system administrators, mission or business owners, system owners, senior agency information security officer, senior agency official for privacy, system security officers, or privacy officers. Automated organization-generated alerts are the security alerts generated by organizations and transmitted using automated means. The sources for organization-generated alerts are focused on other entities such as suspicious activity reports and reports on potential insider threats. In contrast to alerts generated by the organization, alerts generated by the system in [SI-4(5)](#si-4.5) focus on information sources that are internal to the systems, such as audit records. Assessment Objectives: Alert [organization-defined parameter] using [organization-defined parameter] when the following indications of inappropriate or unusual activities with security or privacy implications occur: [organization-defined parameter]. FedRAMP Parameter Values: si-04.12_odp.01: personnel or roles to be alerted when indications of inappropriate or unusual activity with security or privacy implications occur is/are defined; si-04.12_odp.02: automated mechanisms used to alert personnel or roles are defined; si-04.12_odp.03: activities that trigger alerts to personnel or are defined;

Control SI-21: INFORMATION REFRESH Control: Refresh [Assignment: organization-defined information] at [Assignment: organization-defined frequencies] or generate the information on demand and delete the information when no longer needed. Discussion: Retaining information for longer than it is needed makes it an increasingly valuable and enticing target for adversaries. Keeping information available for the minimum period of time needed to support organizational missions or business functions reduces the opportunity for adversaries to compromise, capture, and exfiltrate that information. Related Controls: SI-14. Control Enhancements: None. References: [OMB A-130], [SP 800-160-2].

NIST SP 800-53 Rev 5 control SI-7.7 (Integration of Detection and Response) summarizes the requirements for this control: SI-7.7 · Integration of Detection and Response Control Statement: Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [organization-defined parameter]. Supplemental Guidance: Incorporate the detection of the following unauthorized changes into the organizational incident response capability: [organization-defined parameter]. Integrating detection and response helps to ensure that detected events are tracked, monitored, corrected

3.14.10 Audit Information... 3.14.10 Audit Information Audit information containing key-management events shall be backed up and archived.

NIST SP 800-171 Rev 3 control 03.14.06 (03.14.06 System Monitoring) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Information Integrity (SI) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SI-10.2 (Review and Resolve Errors) is defined as follows: SI-10.2 · Review and Resolve Errors Control Statement: Review and resolve input validation errors within [organization-defined parameter]. Supplemental Guidance: Review and resolve input validation errors within [organization-defined parameter]. Resolution of input validation errors includes correcting systemic causes of errors and resubmitting transactions with corrected input. Input validation errors are those related to the information inputs defined by the organization in the base control ([SI-10](#si-10)).

Organization-generated alerts are focused on information sources that are external 2391 to the system, such as suspicious activity reports and reports on potential insider threats. Organizational personnel on the system alert notification list include system administrators, mission or business owners, system owners, chief information security officers, and system security officers. This requirement enhances SP 800-171 requirement 03.14.06. PROTECTION STRATEGY DLO ADVERSARY EFFECTS Expose (Detect) REFERENCES Source Controls: SI-04(12) 3.15. Planning 03.15.01 E Security Architecture a. Develop a security architecture for the system that: 1. Describes the security requirements and approach to be taken for protecting the confidentiality, integrity, and availability of CUI, 2. Describes how the architecture is integrated into and supports the enterprise architecture, and 3. Describes any assumptions about, and dependencies on, external systems and services. b. Review and update the security architecture [Assignment: organization-defined frequency] to reflect changes in the enterprise architecture. c. Reflect planned security architecture changes in system security plans, concept of operations, criticality analysis, organizational procedures, and procurements and acquisitions. DISCUSSION The security architecture at the system level is consistent with the organization-wide security architecture, which is integral to and developed as part of the enterprise architecture. The security architecture includes an architectural description, the allocation of security functionality (i.e., safeguards and countermeasures), security-related information for external interfaces, information being exchanged across the interfaces, and the protection mechanisms associated with each interface. The

SI-13.5 · Failover Capability Control Statement: Provide [organization-defined parameter] [organization-defined parameter] for the system. Supplemental Guidance: Provide [organization-defined parameter] [organization-defined parameter] for the system. Failover refers to the automatic switchover to an alternate system upon the failure of the primary system. Failover capability includes incorporating mirrored system operations at alternate processing sites or periodic data

mirroring at regular intervals defined by the recovery time periods of organizations.

NIST SP 800-53 Rev 5 control SI-3.10 (Malicious Code Analysis) summarizes the requirements for this control: SI-3.10 · Malicious Code Analysis Control Statement: (a) Employ the following tools and techniques to analyze the characteristics and behavior of malicious code: [organization-defined parameter] ; and (b) Incorporate the results from malicious code analysis into organizational incident response and flaw remediation processes. Supplemental Guidance: (a) Employ the following tools and techniques to analyze the characteristics and behavior of malicious code: [organization-defined parameter] ; and

NIST SP 800-53 Rev 5 control SI-22 (Information Diversity) is assessed by examining, interviewing, and testing: SI-22 · Information Diversity Control Statement: a. Identify the following alternative sources of information for [organization-defined parameter]: [organization-defined parameter] ; and b. Use an alternative information source for the execution of essential functions or services on [organization-defined parameter] when the primary source of information is corrupted or unavailable. Supplemental Guidance: a. Identify the following alternative sources of information for [organization-defined par

NIST SP 800-53 Rev 5 control SI-4.10 (Visibility of Encrypted Communications) is assessed by examining, interviewing, and testing: SI-4.10 · Visibility of Encrypted Communications Control Statement: Make provisions so that [organization-defined parameter] is visible to [organization-defined parameter]. Supplemental Guidance: Make provisions so that [organization-defined parameter] is visible to [organization-defined parameter]. Organizations balance the need to encrypt communications traffic to protect data confidentiality with the need to maintain visibility into such traffic from a monitoring perspective. Organizations

NIST SP 800-53 Rev 5 control SI-4.5 (System-generated Alerts) is assessed by examining, interviewing, and testing: SI-4.5 · System-generated Alerts Control Statement: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Supplemental Guidance: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Alerts may be generated from a variety of sources, including audit records or inputs from m

NIST SP 800-53 Rev 5 control SI-10.1 (Manual Override Capability) summarizes the requirements for this control: SI-10.1 · Manual Override Capability Control Statement: (a) Provide a manual override capability for input validation of the following information inputs: [organization-defined parameter]; (b) Restrict the use of the manual override capability to only [organization-defined parameter] ; and (c) Audit the use of the manual override capability. Supplemental Guidance: (a) Provide a manual override capability for input validation of the following information inputs: [organization-defined parameter]

NIST SP 800-53 Rev 5 control SI-6.2 (Automation Support for Distributed Testing) summarizes the requirements for this control: SI-6.2 · Automation Support for Distributed Testing Control Statement: Implement automated mechanisms to support the management of distributed security and privacy function testing. Supplemental Guidance: Implement automated mechanisms to support the management of distributed security and privacy function testing. The use of automated mechanisms to support the management of distributed function testing helps to ensure the integrity, timeliness, completeness, and efficacy of such testing.

NIST SP 800-53 Rev 5 control SI-14.3 (Non-persistent Connectivity) is assessed by examining, interviewing, and testing: SI-14.3 · Non-persistent Connectivity Control Statement: Establish connections to the system on demand and terminate connections after [organization-defined parameter]. Supplemental Guidance: Establish connections to the system on demand and terminate connections after [organization-defined parameter]. Persistent connections to systems can provide advanced adversaries with paths to move laterally through systems and potentially position themselves closer to high value assets. Limiting the avai

NIST SP 800-53 Rev 5 control SI-7.9 (Verify Boot Process) is assessed by examining, interviewing, and testing: SI-7.9 · Verify Boot Process Control Statement: Verify the integrity of the boot

process of the following system components: [organization-defined parameter]. Supplemental Guidance: Verify the integrity of the boot process of the following system components: [organization-defined parameter]. Ensuring the integrity of boot processes is critical to starting system components in known, trustworthy states. Integrity verification mechanisms provide a level of assurance that only trusted code is exe

Under the FedRAMP Moderate baseline, SI-4.5 (SI-4.5 System-generated Alerts): FedRAMP Moderate Baseline · SI-4.5 · System-generated Alerts Control Statement: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Supplemental Guidance: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Alerts may be generated from a variety of sources, including au

NIST SP 800-171 Rev 3 control 03.14.08 (03.14.08 Information Management and Retention) requires organizations to implement the following: 03.14.08 · Information Management and Retention

Supplemental Guidance: Federal agencies consider data retention requirements for nonfederal organizations. Retaining CUI on nonfederal systems after contracts or agreements have concluded increases the attack surface for those systems and the risk of the information being compromised. NARA provides federal policy and guidance on records retention and schedules. Assessment Objectives: - CUI within the system is managed in accordance with applicabl For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.14.08.

Under the FedRAMP High baseline, SI-12 (SI-12 Information Management and Retention): FedRAMP High Baseline · SI-12 · Information Management and Retention Control Statement: Manage and retain information within the system and information output from the system in accordance with applicable laws, executive orders, directives, regulations, policies, standards, guidelines and operational requirements. Supplemental Guidance: Manage and retain information within the system and information output from the system in accordance with applicable laws, executive orders, directives, regula

NIST SP 800-53 Rev 5 control SI-6.2 (Automation Support for Distributed Testing) is defined as follows: SI-6.2 · Automation Support for Distributed Testing Control Statement: Implement automated mechanisms to support the management of distributed security and privacy function testing. Supplemental Guidance: Implement automated mechanisms to support the management of distributed security and privacy function testing. The use of automated mechanisms to support the management of distributed function testing helps to ensure the integrity, timeliness, completeness, and efficacy of such testing.

NIST SP 800-53 Rev 5 control SI-4.4 (Inbound and Outbound Communications Traffic) is defined as follows: SI-4.4 · Inbound and Outbound Communications Traffic Control Statement: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic; (b) Monitor inbound and outbound communications traffic [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic; (b) Monitor inbound and outbound communications traffic [organization-defined parameter] for [organization-defined parameter].

SI-3.8 · Detect Unauthorized Commands Control Statement: (a) Detect the following unauthorized operating system commands through the kernel application programming interface on [organization-defined parameter]: [organization-defined parameter] ; and (b) [organization-defined parameter]. Supplemental Guidance: (a) Detect the following unauthorized operating system commands through the kernel application programming interface on [organization-defined parameter]: [organization-defined parameter] ; and (b) [organization-defined parameter]. Detecting unauthorized commands can be applied to critical interfaces other than kernel-based interfaces, including interfaces with virtual machines and privileged applications. Unauthorized operating system commands include commands for kernel functions from system processes that are not trusted to initiate such commands as well as commands for kernel functions that are suspicious even though commands of that type are reasonable for processes to initiate. Organizations can define the malicious commands to be detected by a

combination of command types, command classes, or specific instances of commands. Organizations can also define hardware components by component type, component, component location in the network, or a combination thereof. Organizations may select different actions for different types, classes, or instances of malicious commands.

NIST SP 800-53 Rev 5 control SI-4.11 (Analyze Communications Traffic Anomalies) is assessed by examining, interviewing, and testing: SI-4.11 · Analyze Communications Traffic Anomalies Control Statement: Analyze outbound communications traffic at the external interfaces to the system and selected [organization-defined parameter] to discover anomalies. Supplemental Guidance: Analyze outbound communications traffic at the external interfaces to the system and selected [organization-defined parameter] to discover anomalies. Organization-defined interior points include subnetworks and subsystems. Anomalies within organizational

NIST SP 800-53 Rev 5 control SI-4.5 (System-generated Alerts) summarizes the requirements for this control: SI-4.5 · System-generated Alerts Control Statement: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Supplemental Guidance: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Alerts may be generated from a variety of sources, including audit records or inputs from m

SI-4.22 · Unauthorized Network Services Control Statement: (a) Detect network services that have not been authorized or approved by [organization-defined parameter] ; and (b) [organization-defined parameter] when detected. Supplemental Guidance: (a) Detect network services that have not been authorized or approved by [organization-defined parameter] ; and (b) [organization-defined parameter] when detected. Unauthorized or unapproved network services include services in service-oriented architectures that lack organizational verification or validation and may therefore be unreliable or serve as malicious rogues for valid services.

NIST SP 800-53 Rev 5 control SI-7.15 (Code Authentication) is assessed by examining, interviewing, and testing: SI-7.15 · Code Authentication Control Statement: Implement cryptographic mechanisms to authenticate the following software or firmware components prior to installation: [organization-defined parameter]. Supplemental Guidance: Implement cryptographic mechanisms to authenticate the following software or firmware components prior to installation: [organization-defined parameter]. Cryptographic authentication includes verifying that software or firmware components have been digitally signed using

NIST SP 800-53 Rev 5 control SI-18 (Personally Identifiable Information Quality Operations) is assessed by examining, interviewing, and testing: SI-18 · Personally Identifiable Information Quality Operations Control Statement: a. Check the accuracy, relevance, timeliness, and completeness of personally identifiable information across the information life cycle [organization-defined parameter] ; and b. Correct or delete inaccurate or outdated personally identifiable information. Supplemental Guidance: a. Check the accuracy, relevance, timeliness, and completeness of personally identifiable information across the information life cycle [

NIST SP 800-53 Rev 5 control SI-21 (Information Refresh) is defined as follows: SI-21 · Information Refresh Control Statement: Refresh [organization-defined parameter] at [organization-defined parameter] or generate the information on demand and delete the information when no longer needed. Supplemental Guidance: Refresh [organization-defined parameter] at [organization-defined parameter] or generate the information on demand and delete the information when no longer needed. Retaining information for longer than it is needed makes it an increasingly valuable and enticing target for adversaries. Keeping information available for the minimum period of time needed to suppo

From the NIST SP 800-172 Rev 3 Final Public Draft: Expose (Detect, Reveal) 1580 REFERENCES Source Control: SI-04(24) 03.1 1.10E Criticality Analysis Identify critical system components and functions by performing a criticality analysis for [Assignment: organization-defined systems, system components, or system services] at [Assignment: organization-defined decision points in the system development life cycle]. DISCUSSION Organizations conduct a functional decomposition of a system to identify mission-critical functions and system components. The functional decomposition includes the identification of organizational missions supported by the system, the specific

functions to perform those missions, and traceability to the hardware, software, and firmware components that implement those functions, including when the functions

NIST SP 800-53 Rev 5 control SI-7.16 (Time Limit on Process Execution Without Supervision) summarizes the requirements for this control: SI-7.16 · Time Limit on Process Execution Without Supervision Control Statement: Prohibit processes from executing without supervision for more than [organization-defined parameter]. Supplemental Guidance: Prohibit processes from executing without supervision for more than [organization-defined parameter]. Placing a time limit on process execution without supervision is intended to apply to processes for which typical or normal execution periods can be determined and situations in which organi

NIST SP 800-53 Rev 5 control SI-19.5 (Statistical Disclosure Control) is assessed by examining, interviewing, and testing: SI-19.5 · Statistical Disclosure Control Control Statement: Manipulate numerical data, contingency tables, and statistical findings so that no individual or organization is identifiable in the results of the analysis. Supplemental Guidance: Manipulate numerical data, contingency tables, and statistical findings so that no individual or organization is identifiable in the results of the analysis. Many types of statistical analyses can result in the disclosure of information about individuals ev

NIST SP 800-53 Rev 5 control SI-3.8 (Detect Unauthorized Commands) summarizes the requirements for this control: SI-3.8 · Detect Unauthorized Commands Control Statement: (a) Detect the following unauthorized operating system commands through the kernel application programming interface on [organization-defined parameter]: [organization-defined parameter] ; and (b) [organization-defined parameter]. Supplemental Guidance: (a) Detect the following unauthorized operating system commands through the kernel application programming interface on [organization-defined parameter]: [organization-defined parameter]

NIST SP 800-53 Rev 5 control SI-7.16 (Time Limit on Process Execution Without Supervision) is assessed by examining, interviewing, and testing: SI-7.16 · Time Limit on Process Execution Without Supervision Control Statement: Prohibit processes from executing without supervision for more than [organization-defined parameter]. Supplemental Guidance: Prohibit processes from executing without supervision for more than [organization-defined parameter]. Placing a time limit on process execution without supervision is intended to apply to processes for which typical or normal execution periods can be determined and situations in which organi

NIST SP 800-53 Rev 5 control SI-19.7 (Validated Algorithms and Software) is assessed by examining, interviewing, and testing: SI-19.7 · Validated Algorithms and Software Control Statement: Perform de-identification using validated algorithms and software that is validated to implement the algorithms. Supplemental Guidance: Perform de-identification using validated algorithms and software that is validated to implement the algorithms. Algorithms that appear to remove personally identifiable information from a dataset may in fact leave information that is personally identifiable or data that is re-identifiable. Softwar

Under the FedRAMP High baseline, SI-2 (SI-2 Flaw Remediation): FedRAMP High Baseline · SI-2 · Flaw Remediation Control Statement: a. Identify, report, and correct system flaws; b. Test software and firmware updates related to flaw remediation for effectiveness and potential side effects before installation; c. Install security-relevant software and firmware updates within [organization-defined parameter] of the release of the updates; and d. Incorporate flaw remediation into the organizational configuration management process. Supplemental Guidance: a. Id

NIST SP 800-53 Rev 5 control SI-18.5 (Notice of Correction or Deletion) summarizes the requirements for this control: SI-18.5 · Notice of Correction or Deletion Control Statement: Notify [organization-defined parameter] and individuals that the personally identifiable information has been corrected or deleted. Supplemental Guidance: Notify [organization-defined parameter] and individuals that the personally identifiable information has been corrected or deleted. When personally identifiable information is corrected or deleted, organizations take steps to ensure that all authorized recipients of such informati

Under the FedRAMP Moderate baseline, SI-16 (SI-16 Memory Protection): FedRAMP Moderate Baseline · SI-16 · Memory Protection Control Statement: Implement the following controls to protect the system

memory from unauthorized code execution: [organization-defined parameter]. Supplemental Guidance: Implement the following controls to protect the system memory from unauthorized code execution: [organization-defined parameter]. Some adversaries launch attacks with the intent of executing code in non-executable regions of memory or in memory locations that are prohibit

Control SI-4(21): si publication is available free of charge from :

<https://doi.org/10.6028/NIST.SP.800-53r5> I. NIST SP 800-53, REV.

5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

CONTROL NUMBER	CONTROL NAME	CONTROL ENHANCEMENT NAME	IMPLEMENTED BY ASSURANCE
----------------	--------------	--------------------------	--------------------------

From the NIST SP 800-172 Rev 3 Final Public Draft: This requirement is sourced to a control tailored out of the SP 800-53B 2288 [13] moderate baseline in SP 800-1 71. PR OTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert) REFERENCES Source Control: SI-16 03.14.15E Non-P ersistent System Components and Services a. Implement non-persistent [Assignment: organization-defined system components and services] . b. Initiate non-persistent system components and services from a known state. c. Terminate non-persistent system components and services [Selection (one or more): upon end of session of use; [Assignment: organization-defined frequency]]. DISCUSSION Implementation of non-persistent components and services mitigates risk from advanced persistent threats (APTs) by reducing the targeting capability of

NIST SP 800-171 Rev 3 control 03.14.01 (03.14.01 Flaw Remediation) requires organizations to implement the following: Control Statement: SR-03.14.01.a Identify, report, and correct system flaws. SR-03.14.01.b Install security-relevant software and firmware updates within [organization-defined parameter] of the release of the updates. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.14.01.

NIST SP 800-53 Rev 5 control SI-4.25 (Optimize Network Traffic Analysis) summarizes the requirements for this control: SI-4.25 · Optimize Network Traffic Analysis Control Statement: Provide visibility into network traffic at external and key internal system interfaces to optimize the effectiveness of monitoring devices. Supplemental Guidance: Provide visibility into network traffic at external and key internal system interfaces to optimize the effectiveness of monitoring devices. Encrypted traffic, asymmetric routing architectures, capacity and latency limitations, and transitioning from older to newer technol

[Assignment: organization-defined frequency]]. Discussion: System monitoring includes external and internal monitoring. External monitoring includes the observation of events occurring at external interfaces to the system. Internal monitoring includes the observation of events occurring within the system.

NIST SP 800-53 Rev 5 control SI-7.10 (Protection of Boot Firmware) is assessed by examining, interviewing, and testing: SI-7.10 · Protection of Boot Firmware Control Statement: Implement the following mechanisms to protect the integrity of boot firmware in [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement the following mechanisms to protect the integrity of boot firmware in [organization-defined parameter]: [organization-defined parameter]. Unauthorized modifications to boot firmware may indicate a sophisticated, targeted attack. These types of targeted attacks

Under the FedRAMP High baseline, SI-4.20 (SI-4.20 Privileged Users): FedRAMP High Baseline · SI-4.20 · Privileged Users Control Statement: Implement the following additional monitoring of privileged users: [organization-defined parameter]. Supplemental Guidance: Implement the following additional monitoring of privileged users: [organization-defined parameter]. Privileged users have access to more sensitive information, including security-related information, than the general user population. Access to such information means that privileged users can potentiall

NIST SP 800-53 Rev 5 control SI-19.4 (Removal, Masking, Encryption, Hashing, or Replacement of Direct Identifiers) is assessed by examining, interviewing, and testing: SI-19.4 · Removal, Masking, Encryption, Hashing, or Replacement of Direct Identifiers Control Statement: Remove, mask, encrypt, hash, or replace direct identifiers in a dataset. Supplemental Guidance: Remove, mask,

encrypt, hash, or replace direct identifiers in a dataset. There are many possible processes for removing direct identifiers from a dataset. Columns in a dataset that contain a direct identifier can be removed. In masking, the direct identifier is transformed into a repeating charac

NIST SP 800-53 Rev 5 control SI-3.6 (Testing and Verification) summarizes the requirements for this control: SI-3.6 · Testing and Verification Control Statement: (a) Test malicious code protection mechanisms [organization-defined parameter] by introducing known benign code into the system; and (b) Verify that the detection of the code and the associated incident reporting occur. Supplemental Guidance: (a) Test malicious code protection mechanisms [organization-defined parameter] by introducing known benign code into the system; and (b) Verify that the detection of the code and the associated incident

NIST SP 800-53 Rev 5 control SI-18.1 (Automation Support) summarizes the requirements for this control: SI-18.1 · Automation Support Control Statement: Correct or delete personally identifiable information that is inaccurate or outdated, incorrectly determined regarding impact, or incorrectly de-identified using [organization-defined parameter]. Supplemental Guidance: Correct or delete personally identifiable information that is inaccurate or outdated, incorrectly determined regarding impact, or incorrectly de-identified using [organization-defined parameter]. The use of automated mechanisms to

SI-4.7 · Automated Response to Suspicious Events Control Statement: (a) Notify [organization-defined parameter] of detected suspicious events; and (b) Take the following actions upon detection: [organization-defined parameter]. Supplemental Guidance: (a) Notify [organization-defined parameter] of detected suspicious events; and (b) Take the following actions upon detection: [organization-defined parameter]. Least-disruptive actions include initiating requests for human responses.

NIST SP 800-53 Rev 5 control SI-4.7 (Automated Response to Suspicious Events) is assessed by examining, interviewing, and testing: SI-4.7 · Automated Response to Suspicious Events Control Statement: (a) Notify [organization-defined parameter] of detected suspicious events; and (b) Take the following actions upon detection: [organization-defined parameter]. Supplemental Guidance: (a) Notify [organization-defined parameter] of detected suspicious events; and (b) Take the following actions upon detection: [organization-defined parameter]. Least-disruptive actions include initiating requests for human responses.

SI-7.10 · Protection of Boot Firmware Control Statement: Implement the following mechanisms to protect the integrity of boot firmware in [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement the following mechanisms to protect the integrity of boot firmware in [organization-defined parameter]: [organization-defined parameter]. Unauthorized modifications to boot firmware may indicate a sophisticated, targeted attack. These types of targeted attacks can result in a permanent denial of service or a persistent malicious code presence. These situations can occur if the firmware is corrupted or if the malicious code is embedded within the firmware. System components can protect the integrity of boot firmware in organizational systems by verifying the integrity and authenticity of all updates to the firmware prior to applying changes to the system component and preventing unauthorized processes from modifying the boot firmware.

NIST SP 800-53 Rev 5 control SI-17 (Fail-safe Procedures) is defined as follows: SI-17 · Fail-safe Procedures Control Statement: Implement the indicated fail-safe procedures when the indicated failures occur: [organization-defined parameter]. Supplemental Guidance: Implement the indicated fail-safe procedures when the indicated failures occur: [organization-defined parameter]. Failure conditions include the loss of communications among critical system components or between system components and operational facilities. Fail-safe procedures include alerting operator personnel and providing specific instructions on subsequent steps to take. Subsequent steps may include doin

NIST SP 800-53 Rev 5 control SI-4.20 (Privileged Users) is defined as follows: SI-4.20 · Privileged Users Control Statement: Implement the following additional monitoring of privileged users: [organization-defined parameter]. Supplemental Guidance: Implement the following additional monitoring of privileged users: [organization-defined parameter]. Privileged users have access to more sensitive information, including security-related information, than the general user

population. Access to such information means that privileged users can potentially do greater damage to systems and organizations than non-privileged users. Therefore, implementing additional monitoring on

03.14.01 · Flaw Remediation Control Statement: SR-03.14.01.a Identify, report, and correct system flaws. SR-03.14.01.b Install security-relevant software and firmware updates within [organization-defined parameter] of the release of the updates. Supplemental Guidance: Organizations identify systems that are affected by announced software and firmware flaws, including potential vulnerabilities that result from those flaws, and report this information to designated personnel with information security responsibilities. Security-relevant updates include patches, service packs, hot fixes, and anti-virus signatures. Organizations address the flaws discovered during security assessments, continuous monitoring, incident response activities, and system error handling. Organizations can take advantage of available resources (e.g., CWE or CVE databases) when remediating system flaws. Organization-defined time periods for updating security-relevant software and firmware may vary based on a variety of factors, including the criticality of the update (i.e., severity of the vulnerability related to the discovered flaw). Some types of flaw remediation may require more testing than other types. Assessment Objectives: - system flaws are identified. - system flaws are reported. - system flaws are corrected. - security-relevant software updates are installed within [organization-defined parameter] of the release of the updates. - security-relevant firmware updates are installed within [organization-defined parameter] of the release of the updates. Organization-Defined Parameters: - A.03.14.01.ODP.01: time period - A.03.14.01.ODP.02: time period

NIST SP 800-53 Rev 5 control SI-4.1 (System-wide Intrusion Detection System) summarizes the requirements for this control: SI-4.1 · System-wide Intrusion Detection System Control Statement: Connect and configure individual intrusion detection tools into a system-wide intrusion detection system. Supplemental Guidance: Connect and configure individual intrusion detection tools into a system-wide intrusion detection system. Linking individual intrusion detection tools into a system-wide intrusion detection system provides additional coverage and effective detection capabilities. The information contained in one intru

NIST SP 800-53 Rev 5 control SI-5.1 (Automated Alerts and Advisories) summarizes the requirements for this control: SI-5.1 · Automated Alerts and Advisories Control Statement: Broadcast security alert and advisory information throughout the organization using [organization-defined parameter]. Supplemental Guidance: Broadcast security alert and advisory information throughout the organization using [organization-defined parameter]. The significant number of changes to organizational systems and environments of operation requires the dissemination of security-related information to a variety of organizational

NIST SP 800-53 Rev 5 control SI-6.3 (Report Verification Results) summarizes the requirements for this control: SI-6.3 · Report Verification Results Control Statement: Report the results of security and privacy function verification to [organization-defined parameter]. Supplemental Guidance: Report the results of security and privacy function verification to [organization-defined parameter]. Organizational personnel with potential interest in the results of the verification of security and privacy functions include systems security officers, senior agency information security officers, and senior agency

NIST SP 800-53 Rev 5 control SI-14 (Non-persistence) summarizes the requirements for this control: SI-14 · Non-persistence Control Statement: Implement non-persistent [organization-defined parameter] that are initiated in a known state and terminated [organization-defined parameter]. Supplemental Guidance: Implement non-persistent [organization-defined parameter] that are initiated in a known state and terminated [organization-defined parameter]. Implementation of non-persistent components and services mitigates risk from advanced persistent threats (APTs) by reducing the targeting capabili

Under the FedRAMP High baseline, SI-4.16 (SI-4.16 Correlate Monitoring Information): FedRAMP High Baseline · SI-4.16 · Correlate Monitoring Information Control Statement: Correlate information from monitoring tools and mechanisms employed throughout the system. Supplemental Guidance: Correlate information from monitoring tools and mechanisms employed throughout the system. Correlating information from different system monitoring tools and mechanisms can provide a more comprehensive

view of system activity. Correlating system monitoring tools and mechanisms that typically work

NIST SP 800-53 Rev 5 control SI-6 (Security and Privacy Function Verification) is assessed by examining, interviewing, and testing: SI-6 · Security and Privacy Function Verification Control Statement: a. Verify the correct operation of [organization-defined parameter]; b. Perform the verification of the functions specified in SI-6a [organization-defined parameter]; c. Alert [organization-defined parameter] to failed security and privacy verification tests; and d. [organization-defined parameter] when anomalies are discovered. Supplemental Guidance: a. Verify the correct operation of [organization-defined parameter]; b. Per

Under the FedRAMP High baseline, SI-4.5 (SI-4.5 System-generated Alerts): FedRAMP High Baseline · SI-4.5 · System-generated Alerts Control Statement: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Supplemental Guidance: Alert [organization-defined parameter] when the following system-generated indications of compromise or potential compromise occur: [organization-defined parameter]. Alerts may be generated from a variety of sources, including audit

Under the FedRAMP High baseline, SI-4.14 (SI-4.14 Wireless Intrusion Detection): FedRAMP High Baseline · SI-4.14 · Wireless Intrusion Detection Control Statement: Employ a wireless intrusion detection system to identify rogue wireless devices and to detect attack attempts and potential compromises or breaches to the system. Supplemental Guidance: Employ a wireless intrusion detection system to identify rogue wireless devices and to detect attack attempts and potential compromises or breaches to the system. Wireless signals may radiate beyond organizational facilities. Orga

NIST SP 800-53 Rev 5 control SI-3 (Malicious Code Protection) summarizes the requirements for this control: SI-3 · Malicious Code Protection Control Statement: a. Implement [organization-defined parameter] malicious code protection mechanisms at system entry and exit points to detect and eradicate malicious code; b. Automatically update malicious code protection mechanisms as new releases are available in accordance with organizational configuration management policy and procedures; c. Configure malicious code protection mechanisms to: 1. Perform periodic scans of the system [organization-defined p

SI-4.18 · Analyze Traffic and Covert Exfiltration Control Statement: Analyze outbound communications traffic at external interfaces to the system and at the following interior points to detect covert exfiltration of information: [organization-defined parameter]. Supplemental Guidance: Analyze outbound communications traffic at external interfaces to the system and at the following interior points to detect covert exfiltration of information: [organization-defined parameter]. Organization-defined interior points include subnetworks and subsystems. Covert means that can be used to exfiltrate information include steganography.

NIST SP 800-53 Rev 5 control SI-4.11 (Analyze Communications Traffic Anomalies) is defined as follows: SI-4.11 · Analyze Communications Traffic Anomalies Control Statement: Analyze outbound communications traffic at the external interfaces to the system and selected [organization-defined parameter] to discover anomalies. Supplemental Guidance: Analyze outbound communications traffic at the external interfaces to the system and selected [organization-defined parameter] to discover anomalies. Organization-defined interior points include subnetworks and subsystems. Anomalies within organizational systems include large file transfers, long-time persistent connections, attempts to access informati

NIST SP 800-53 Rev 5 control SI-3.6 (Testing and Verification) is assessed by examining, interviewing, and testing: SI-3.6 · Testing and Verification Control Statement: (a) Test malicious code protection mechanisms [organization-defined parameter] by introducing known benign code into the system; and (b) Verify that the detection of the code and the associated incident reporting occur. Supplemental Guidance: (a) Test malicious code protection mechanisms [organization-defined parameter] by introducing known benign code into the system; and (b) Verify that the detection of the code and the associated incident

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft)
Enhanced Security Requirements for Protecting CUI September 2025 REQUIREMENT NUMBER ENHANCED
SECURITY REQUIREMENT REQUIREMENT TYPE 03.14.15E Non-Persistent System Components and Services S SP

800-53, SI-14 03.14.16E Tainting S SP 800-53, SI-20 03.14.17E System-Generated Alerts T SP 800-53, SI-04(05) 03.14.18E Automated Organization-Generated Alerts E 03.14.06 Planning 03.15.01E Security Architecture T SP 800-53, PL-08 03.15.02E Defense In Depth S SP 800-53, PL-08(01) 03.15.03E Supplier Diversity S SP 800-53, PL-08(02) System and Services Acquisition 03.16.01E Specialization S SP 800-53, SA-23 Supply Chain Risk Management 03.17.01E Notification Agreements T SP 800-53, SR-08 03.17.02E Inspection of Systems or Components T SP

NIST SP 800-53 Rev 5 control SI-18.3 (Collection): SI-18.3 · Collection Control Statement: Collect personally identifiable information directly from the individual. Supplemental Guidance: Collect personally identifiable information directly from the individual. Individuals or their designated representatives can be sources of correct personally identifiable information. Organizations consider contextual factors that may incentivize individuals t

NIST SP 800-53 Rev 5 control SI-19.1 (Collection) is assessed by examining, interviewing, and testing: SI-19.1 · Collection Control Statement: De-identify the dataset upon collection by not collecting personally identifiable information. Supplemental Guidance: De-identify the dataset upon collection by not collecting personally identifiable information. If a data source contains personally identifiable information but the information will not be used, the dataset can be de-identified when it is created by not collecting the data elements that contain the personally identifiable information. For

NIST SP 800-53 Rev 5 control SI-12 (Information Management and Retention) is assessed by examining, interviewing, and testing: SI-12 · Information Management and Retention Control Statement: Manage and retain information within the system and information output from the system in accordance with applicable laws, executive orders, directives, regulations, policies, standards, guidelines and operational requirements. Supplemental Guidance: Manage and retain information within the system and information output from the system in accordance with applicable laws, executive orders, directives, regulations, policies, standar

Control SI-4(12): ed network access from within the physical boundaries of the system, additional monitoring of transitioning traffic between wireless and wired networks may be necessary to detect malicious activities. Employing intrusion detection systems to monitor wireless communications traffic helps to ensure that the traffic does not contain malicious code prior to transitioning to the wireline network. Related Controls: AC-18. (16) SYSTEM MONITORING | CORRELATE MONITORING INFORMATION Correlate information from monitoring tools and mechanisms employed throughout the system. Discussion: Correlating information from different system monitoring tools and mechanisms can provide a more comprehensive view of system activity. Correlating system monitoring tools and mechanisms that typically work in isolation-including malicious code protection software, host monitoring, and network monitoring-can provide an organization-wide monitoring view and may reveal otherwise unseen attack patterns. Understanding the capabilities and limitations of diverse monitoring tools and mechanisms and how to maximize the use of information generated by those tools and mechanisms can help organizations develop, operate, and maintain effective monitoring programs. The correlation of monitoring information is especially important during the transition from older to newer technologies (e.g., transitioning from IPv4 to IPv6 network protocols). Related Controls: AU-6. (17) SYSTEM MONITORING | INTEGRATED SITUATIONAL AWARENESS Correlate information from monitoring physical, cyber, and supply chain activities to achieve integrated, organization-wide situational awareness. Discussion: Correlating monitoring information from a more diverse set of information sources helps to achieve integrated situational awareness.

SI-14.3 · Non-persistent Connectivity Control Statement: Establish connections to the system on demand and terminate connections after [organization-defined parameter]. Supplemental Guidance: Establish connections to the system on demand and terminate connections after [organization-defined parameter]. Persistent connections to systems can provide advanced adversaries with paths to move laterally through systems and potentially position themselves closer to high value assets. Limiting the availability of such connections impedes the adversary-s ability to move freely through organizational systems.

Under the FedRAMP Moderate baseline, SI-4.4 (SI-4.4 Inbound and Outbound Communications Traffic): FedRAMP Moderate Baseline · SI-4.4 · Inbound and Outbound Communications Traffic Control Statement: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound

communications traffic; (b) Monitor inbound and outbound communications traffic [organization-defined parameter] for [organization-defined parameter]. Supplemental Guidance: (a) Determine criteria for unusual or unauthorized activities or conditions for inbound and outbound communications traffic

NIST SP 800-53 Rev 5 control SI-10 (Information Input Validation) is assessed by examining, interviewing, and testing: SI-10 · Information Input Validation Control Statement: Check the validity of the following information inputs: [organization-defined parameter]. Supplemental Guidance: Check the validity of the following information inputs: [organization-defined parameter]. Checking the valid syntax and semantics of system inputs-including character set, length, numerical range, and acceptable values-verifies that inputs match specified definitions for format and content. For example, if the organization spec

Under the FedRAMP High baseline, SI-4.2 (SI-4.2 Automated Tools and Mechanisms for Real-time Analysis): FedRAMP High Baseline · SI-4.2 · Automated Tools and Mechanisms for Real-time Analysis Control Statement: Employ automated tools and mechanisms to support near real-time analysis of events. Supplemental Guidance: Employ automated tools and mechanisms to support near real-time analysis of events. Automated tools and mechanisms include host-based, network-based, transport-based, or storage-based event monitoring tools and mechanisms or security information and event management (SIEM) technologie

NIST SP 800-171 Rev 3 control 03.14.02 (03.14.02 Malicious Code Protection) maps to corresponding controls in NIST SP 800-53 Rev 5 under the System and Information Integrity (SI) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control SI-4.2 (Automated Tools and Mechanisms for Real-time Analysis) summarizes the requirements for this control: SI-4.2 · Automated Tools and Mechanisms for Real-time Analysis Control Statement: Employ automated tools and mechanisms to support near real-time analysis of events. Supplemental Guidance: Employ automated tools and mechanisms to support near real-time analysis of events. Automated tools and mechanisms include host-based, network-based, transport-based, or storage-based event monitoring tools and mechanisms or security information and event management (SIEM) technologies that provide real-time

Under the FedRAMP High baseline, SI-8 (SI-8 Spam Protection): FedRAMP High Baseline · SI-8 · Spam Protection Control Statement: a. Employ spam protection mechanisms at system entry and exit points to detect and act on unsolicited messages; and b. Update spam protection mechanisms when new releases are available in accordance with organizational configuration management policy and procedures. Supplemental Guidance: a. Employ spam protection mechanisms at system entry and exit points to detect and act on unsolicited messages; and b. Update spam protection

NIST SP 800-53 Rev 5 control SI-14.3 (Non-persistent Connectivity) is defined as follows: SI-14.3 · Non-persistent Connectivity Control Statement: Establish connections to the system on demand and terminate connections after [organization-defined parameter]. Supplemental Guidance: Establish connections to the system on demand and terminate connections after [organization-defined parameter]. Persistent connections to systems can provide advanced adversaries with paths to move laterally through systems and potentially position themselves closer to high value assets. Limiting the availability of such connections impedes the adversary's ability to move freely through organizational s

[Assignment: organization-defined alternative action(s)] when anomalies are discovered. Discussion: Transitional states for systems include system startup, restart, shutdown, and abort. System notifications include hardware indicator lights, electronic alerts to system administrators, and messages to local computer consoles. In contrast to security function verification, privacy function verification ensures that privacy functions operate as expected and are approved by the senior agency official for privacy or that privacy attributes are applied or used as expected. Related Controls: CA-7, CM-4, CM-6, SI-7. Control Enhancements: (1) SECURITY AND PRIVACY FUNCTION VERIFICATION | NOTIFICATION OF FAILED SECURITY TESTS [Withdrawn: Incorporated into SI-6.] (2) SECURITY AND PRIVACY FUNCTION VERIFICATION | AUTOMATION SUPPORT FOR DISTRIBUTED TESTING Implement

automated mechanisms to support the management of distributed security and privacy function testing.
CHAPTER THREE PAGE 344 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST SP 800-53, REV.

NIST SP 800-53 Rev 5 control SI-4.11 (Analyze Communications Traffic Anomalies) summarizes the requirements for this control: SI-4.11 · Analyze Communications Traffic Anomalies Control Statement: Analyze outbound communications traffic at the external interfaces to the system and selected [organization-defined parameter] to discover anomalies. Supplemental Guidance: Analyze outbound communications traffic at the external interfaces to the system and selected [organization-defined parameter] to discover anomalies. Organization-defined interior points include subnetworks and subsystems. Anomalies within organizational

NIST SP 800-53 Rev 5 control SI-8.3 (Continuous Learning Capability): SI-8.3 · Continuous Learning Capability Control Statement: Implement spam protection mechanisms with a learning capability to more effectively identify legitimate communications traffic. Supplemental Guidance: Implement spam protection mechanisms with a learning capability to more effectively identify legitimate communications traffic. Learning mechanisms include Bayesian filters that respond to

Control SI-19: knowledge, computational resources, financial resources, data, and skills that intruders possess to conduct the tests. A motivated intruder test can determine if the de-identification is insufficient. It can also be a useful diagnostic tool to assess if de-identification is likely to be sufficient. However, the test alone cannot prove that de-identification is sufficient. Related Controls: None. References: [OMB A-130], [SP 800-188].